

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#Plano de ensino

#Plano de aula

#Metodologia

#Avaliação

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002

A Associação Brasileira de Normas Técnicas (ABNT) é o Foro Nacional de Normalização. As Normas Brasileiras, cujo conteúdo é de responsabilidade dos Comitês Brasileiros (ABNT/CB), dos Organismos de Normalização Setorial (ABNT/ONS) e das Comissões de Estudo Especiais (ABNT/CEE), são elaboradas por Comissões de Estudo (CE), formadas por representantes dos setores envolvidos, delas fazendo parte: produtores, consumidores e neutros (universidades, laboratórios e outros).

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002

A ABNT NBR ISO/IEC 27002 foi elaborada no Comitê Brasileiro de Computadores e Processamento de Dados (ABNT/CB-21), pela Comissão de Estudo de Técnicas de Segurança (CE-21:027.00). O Projeto circulou em Consulta Nacional conforme Edital nº 09, de 26.09.2013 a 25.10.2013, com o número de Projeto ABNT NBR ISO/IEC 27002.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002

Esta Norma relaciona a seguir os termos que foram mantidos na língua inglesa, por não possuírem tradução equivalente para a língua portuguesa com a respectiva descrição:

- Back-up – cópias de segurança de arquivos.
- Firewall – sistema ou combinação de sistemas que protege a fronteira entre duas ou mais redes.
- Gateway – máquina que funciona como ponto de conexão entre duas redes.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002

Esta Norma relaciona a seguir os termos que foram mantidos na língua inglesa, por não possuírem tradução equivalente para a língua portuguesa com a respectiva descrição:

- Hackers – pessoa que tenta acessar sistemas sem autorização, usando técnicas próprias ou não, no intuito de ter acesso a determinado ambiente para proveito próprio ou de terceiros. Dependendo dos objetivos da ação, podem ser chamados de Cracker, Lammer ou BlackHat.
- Logging – processo de estocagem de informações sobre eventos que ocorreram em um firewall ou em uma rede.
- Need to know – conceito que define que uma pessoa só precisa acessar os sistemas necessários para realizar a sua atividade.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002

Esta Norma relaciona a seguir os termos que foram mantidos na língua inglesa, por não possuírem tradução equivalente para a língua portuguesa com a respectiva descrição:

- Patches – correção temporária efetuada em um programa; pequena correção executada pelo usuário no software, com as instruções do fabricante do software.
- Scripts – conjunto de instruções, em geral escritos para automatizar alguma atividade. São também conhecidos como linguagem de scripting ou linguagem de extensão.
- Sign On (SSO) – mecanismo pelo qual uma única ação de autenticação do usuário pode permitir que o mesmo acesse vários ambientes, sistemas e aplicações.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002

Esta Norma relaciona a seguir os termos que foram mantidos na língua inglesa, por não possuírem tradução equivalente para a língua portuguesa com a respectiva descrição:

- Sniffer – ferramentas utilizadas para capturar e opcionalmente analisar tráfego de rede, sem interferir no seu funcionamento.
- Tokens – dispositivos físicos geradores aleatórios de código para uso como forma de autenticação em sistemas.
- Wireless – sistema de comunicação que não requer fios para transportar sinais
- Whitelisting – prática usada para impedir que programas não autorizados sejam executados em um determinado ambiente.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002

Esta Norma é projetada para as organizações usarem como uma referência na seleção de controles dentro do processo de implementação de um sistema de gestão da segurança da informação (SGSI), baseado na ABNT NBR ISO/IEC 27001[10] ou como um documento de orientação para as organizações implementarem controles de segurança da informação comumente aceitos. Esta Norma é também usada no desenvolvimento de organizações e indústrias específicas de gerenciamento de segurança da informação, levando em consideração os seus ambientes de risco de segurança da informação específicos.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002

Organizações de todos os tipos e tamanhos (incluindo o setor privado e público, organizações comerciais e sem fins lucrativos), coletam, processam, armazenam e transmitem informações em diferentes formatos, incluindo o eletrônico, físico e verbal (por exemplo, conversações e apresentações).

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002

O valor da informação vai além das palavras escritas, números e imagens: conhecimento, conceitos, ideias e marcas são exemplos de formas intangíveis da informação. Em um mundo interconectado, a informação e os processos relacionados, sistemas, redes e pessoas envolvidas nas suas operações são informações que, como outros ativos importantes, têm valor para o negócio da organização e, conseqüentemente, requerem proteção contra vários riscos.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002

Ativos são objeto de ameaças, tanto acidentais como deliberadas, enquanto que os processos, sistemas, redes e pessoas têm vulnerabilidades inerentes. Mudanças nos processos e sistemas do negócio ou outras mudanças externas (como novas leis e regulamentações), podem criar novos riscos de segurança da informação. Desta forma, em função das várias maneiras nas quais as ameaças podem se aproveitar das vulnerabilidades para causar dano à organização, os riscos de segurança da informação estão sempre presentes. Uma segurança da informação eficaz reduz estes riscos, protegendo a organização das ameaças e vulnerabilidades e, assim, reduzindo o impacto aos seus ativos.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002

A segurança da informação é alcançada pela implementação de um conjunto adequado de controles, incluindo políticas, processos, procedimentos, estrutura organizacional e funções de software e hardware. Estes controles precisam ser estabelecidos, implementados, monitorados, analisados criticamente e melhorados, quando necessário, para assegurar que os objetivos do negócio e a segurança da informação da organização sejam atendidos. Um sistema de gestão da segurança da informação (SGSI), a exemplo do especificado na ABNT NBR ISO/IEC 27001[10], considera uma visão holística e coordenada dos riscos de segurança da informação da organização, para implementar um conjunto de controles de segurança da informação detalhado, com base na estrutura global de um sistema de gestão coerente.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002

Muitos sistemas de informação não têm sido projetados para serem seguros, na ótica da ABNT NBR ISO/IEC 27001[10] e desta Norma. A segurança que pode ser alcançada através de meios técnicos é limitada e está apoiada por procedimentos e gerenciamentos apropriados. A identificação de quais controles devem ser implementados requer planejamento e atenção cuidadosa em nível de detalhes. Um sistema de gestão da segurança da informação bem-sucedido requer apoio de todos os funcionários da organização. Isto pode também exigir a participação de acionistas, fornecedores ou outras partes externas.

Orientações de especialistas externos podem também ser necessárias.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002

De um modo geral, uma segurança da informação eficaz também garante à direção e a outras partes interessadas que os ativos da organização estão razoavelmente seguros e protegidos contra danos, agindo como um facilitador dos negócios.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002

Requisitos de segurança da informação

É essencial que uma organização identifique os seus requisitos de segurança da informação. Existem três fontes principais de requisitos de segurança da informação.

a) a avaliação de riscos para a organização, levando-se em conta os objetivos e as estratégias globais de negócio da organização. Por meio da avaliação de riscos, são identificadas as ameaças aos ativos e as vulnerabilidades destes, e realizada uma estimativa da probabilidade de ocorrência das ameaças e do impacto potencial ao negócio.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002

Requisitos de segurança da informação

- b) a legislação vigente, os estatutos, a regulamentação e as cláusulas contratuais que a organização, seus parceiros comerciais, contratados e provedores de serviço têm que atender, além do seu ambiente sociocultural.
- c) os conjuntos particulares de princípios, objetivos e os requisitos do negócio para o manuseio, processamento, armazenamento, comunicação e arquivo da informação, que uma organização tem que desenvolver para apoiar suas operações.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002

Os recursos empregados na implementação dos controles precisam ser balanceados com base na probabilidade de danos ao negócio, resultado dos problemas de segurança pela ausência desses controles. Os resultados de uma avaliação de risco ajudarão a orientar e determinar as ações de gestão apropriadas e as prioridades para gerenciar os riscos de segurança da informação e a implementação dos controles selecionados para proteger contra estes riscos.

A ABNT NBR ISO/IEC 27005[11] fornece diretrizes sobre gestão de riscos de segurança da informação, incluindo orientações sobre avaliação de riscos, tratamentos de riscos, aceitação de riscos, comunicação de riscos, monitoramento e análise crítica dos riscos.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002

Seleção de controle

Controles podem ser selecionados desta Norma ou de outros conjuntos de controles, ou novos controles podem ser projetados para atender às necessidades específicas, conforme apropriado.

A seleção de controles de segurança da informação depende das decisões da organização, baseadas nos critérios para aceitação de risco, nas opções para tratamento do risco e no enfoque geral da gestão de risco aplicado à organização, e convém que a seleção destes controles também esteja sujeita a todas as legislações e regulamentações nacionais e internacionais relevantes. A seleção de controles também depende da maneira pela qual os controles interagem para prover uma proteção segura.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002

Alguns dos controles nesta Norma podem ser considerados princípios básicos para a gestão da segurança da informação e podem ser aplicados à maioria das organizações. Os controles são explicados em mais detalhes logo a seguir, no campo diretrizes para implementação. Mais informações sobre seleção de controles e outras opções para tratamento de riscos podem ser encontradas na ABNT NBR ISO/IEC 27005[11].

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002

Desenvolvendo suas próprias diretrizes

Esta Norma pode ser considerada um ponto de partida para o desenvolvimento de diretrizes específicas para a organização. Nem todos os controles e diretrizes contidos neste código de prática podem ser aplicados. Além disto, controles adicionais e recomendações não incluídas nesta Norma, podem ser necessários. Quando os documentos são desenvolvidos contendo controles ou recomendações adicionais, pode ser útil realizar uma referência cruzada com as seções desta Norma, onde aplicável, para facilitar a verificação da conformidade por auditores e parceiros de negócio.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002

Considerações sobre o ciclo de vida

A informação tem um ciclo de vida natural, desde a sua criação e origem, armazenamento, processamento, uso e transmissão, até a sua eventual destruição ou obsolescência. O valor e os riscos aos ativos podem variar durante o tempo de vida da informação (por exemplo, revelação não autorizada ou roubo de balanços financeiros de uma companhia é muito menos importante depois que eles são formalmente publicados), porém a segurança da informação permanece importante em algumas etapas de todos os estágios.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002

Sistemas de informação têm ciclos de vida nos quais eles são concebidos, especificados, projetados, desenvolvidos, testados, implementados, usados, mantidos e, eventualmente, retirados do serviço e descartados. Convém que a segurança da informação seja considerada em cada estágio. Desenvolvimentos de sistemas novos e mudanças nos sistemas existentes são oportunidades para as organizações atualizarem e melhorarem os controles de segurança, levando em conta os incidentes reais e os riscos de segurança da informação, projetados e atuais.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002

Normas relacionadas

Enquanto esta Norma oferece uma diretriz em uma ampla gama de controles de segurança da informação, que são normalmente aplicados em muitas organizações diferentes, as outras partes da família de normas ISO/IEC 27000 fornece orientações complementares ou requisitos sobre outros aspectos do processo global de gerenciamento da segurança da informação.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002

Normas relacionadas

A ISO/IEC 27000 apresenta uma introdução geral de um sistema de gestão da segurança da informação e da família de normas da série ISO/IEC 27000. A ISO/IEC 27000 fornece um glossário, contendo definições da maioria dos termos usados em toda a família de normas da série ISO/IEC 27000, e descreve o escopo e objetivos para cada membro da família.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002

Tecnologia da informação — Técnicas de segurança — Código de prática para controles de segurança da informação

Escopo

Esta Norma fornece diretrizes para práticas de gestão de segurança da informação e normas de segurança da informação para as organizações, incluindo a seleção, a implementação e o gerenciamento de controles, levando em consideração os ambientes de risco da segurança da informação da organização.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002

Esta Norma é projetada para ser usada por organizações que pretendam:

- a) selecionar controles dentro do processo de implementação de um sistema de gestão da segurança da informação baseado na ABNT NBR ISO/IEC 27001[6];
- b) implementar controles de segurança da informação comumente aceitos;
- c) desenvolver seus próprios princípios de gestão da segurança da informação.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002

Categorias de controles:

- a) um objetivo de controle declarando o que se espera que seja alcançado;
- b) um ou mais controles que podem ser aplicados para se alcançar o objetivo do controle.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002

As descrições do controle estão estruturadas da seguinte forma:

Controle: Define a declaração específica do controle, para atender ao objetivo de controle.

Diretrizes para implementação: Apresenta informações mais detalhadas para apoiar a implementação do controle e alcançar o objetivo do controle. As diretrizes podem não ser totalmente adequadas ou suficientes em todas as situações e podem, portanto, não atender completamente aos requisitos de controle específicos da organização.

Informações adicionais: Apresenta mais dados que podem ser considerados, como por exemplo, questões legais e referências normativas. Se não existirem informações adicionais, esta parte não é mostrada no controle.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002

Categorias de controles: Cada seção principal contém:

Controle: Define a declaração específica do controle, para atender ao objetivo de controle.

Diretrizes para implementação: Apresenta informações mais detalhadas para apoiar a implementação do controle e alcançar o objetivo do controle. As diretrizes podem não ser totalmente adequadas ou suficientes em todas as situações e podem, portanto, não atender completamente aos requisitos de controle específicos da organização.

Informações adicionais: Apresenta mais dados que podem ser considerados, como por exemplo, questões legais e referências normativas. Se não existirem informações adicionais, esta parte não é mostrada no controle.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002

- Cap. 5 = Políticas de segurança da informação
- 5.1 = Orientação da direção para segurança da informação
 - 5.1.1 = Políticas para segurança da informação
 - 5.1.2 = Análise crítica das políticas para segurança da informação

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Políticas de segurança da informação

Orientação da direção para segurança da informação

Objetivo: Prover da Direção a orientação e apoio para a segurança da informação, de acordo com os requisitos do negócio e com as leis e regulamentações relevantes.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Políticas de segurança da informação

Orientação da direção para segurança da informação

Políticas para segurança da informação: Controle

Convém que um conjunto de políticas de segurança da informação seja definido, aprovado pela direção, publicado e comunicado para todos os funcionários e partes externas relevantes.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Políticas de segurança da informação

Orientação da direção para segurança da informação

Políticas para segurança da informação: Diretrizes para implementação

Convém que, no mais alto nível, a organização defina uma política de segurança da informação, que seja aprovada pela direção e estabeleça a abordagem da organização para gerenciar os objetivos de segurança da informação.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Políticas de segurança da informação

Orientação da direção para segurança da informação

Políticas para segurança da informação: Diretrizes para implementação

Convém que as políticas de segurança da informação contemplem requisitos oriundos de:

- a) estratégia do negócio;
- b) regulamentações, legislação e contratos;
- c) ambiente de ameaça da segurança da informação, atual e futuro

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Políticas de segurança da informação

Orientação da direção para segurança da informação

Políticas para segurança da informação: Diretrizes para implementação

Convém que a política de segurança da informação contenha declarações relativas a:

- a) definição de segurança da informação, objetivos e princípios para orientar todas as atividades relativas à segurança da informação;
- b) atribuição de responsabilidades, gerais e específicas, para o gerenciamento da segurança da informação para os papéis definidos;
- c) processos para o tratamento dos desvios e exceções.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Políticas de segurança da informação

Orientação da direção para segurança da informação

Políticas para segurança da informação: Diretrizes para implementação

No nível mais baixo, convém que a política de segurança da informação seja apoiada por políticas específicas do tema, que exigem a implementação de controles de segurança e que sejam estruturadas para considerar as necessidades de certos grupos de interesse dentro da organização ou para cobrir tópicos específicos.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Políticas de segurança da informação

Orientação da direção para segurança da informação

Políticas para segurança da informação: Diretrizes para implementação

São exemplos de tais temas de política:

- a) controle de acesso;
- b) classificação e tratamento da informação;
- c) segurança física e do ambiente;
- d) tópicos orientados aos usuários finais

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Políticas de segurança da informação

Orientação da direção para segurança da informação

Políticas para segurança da informação: Informações adicionais

A necessidade de políticas internas de segurança da informação varia entre organizações. Políticas internas são especialmente úteis em organizações maiores e mais complexas onde aqueles que definem e aprovam os níveis esperados de controle são segregados daqueles que implementam os controles, ou em situações onde uma política se aplica a muitas pessoas ou funções diferentes na organização. Políticas de segurança da informação podem ser emitidas em um único documento, “política de segurança da informação” ou como um conjunto de documentos individuais, relacionados.

Se qualquer uma das políticas de segurança da informação for distribuída fora da organização, convém que cuidados sejam tomados para não divulgar informações confidenciais.

Algumas organizações usam outros termos para estes documentos da política, como “Normas”, “Diretrizes” ou “Regras”.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Políticas de segurança da informação

Orientação da direção para segurança da informação

Análise crítica das políticas para segurança da informação: Controle

Convém que as políticas de segurança da informação sejam analisadas criticamente a intervalos planejados ou quando mudanças significativas ocorrerem, para assegurar a sua contínua pertinência, adequação e eficácia.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Políticas de segurança da informação

Orientação da direção para segurança da informação

Análise crítica das políticas para segurança da informação: Diretrizes para implementação

Convém que cada política de segurança da informação tenha um gestor com a responsabilidade pelo desenvolvimento, análise crítica e avaliação das políticas de segurança da informação.

Convém que a análise crítica inclua a avaliação de oportunidades para melhoria da política de segurança da informação da organização e tenha um enfoque para gerenciar a segurança da informação em resposta às mudanças ao ambiente organizacional, às circunstâncias do negócio, às condições legais ou ao ambiente de tecnologia.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Políticas de segurança da informação

Orientação da direção para segurança da informação

Análise crítica das políticas para segurança da informação: Informações adicionais

Convém que a análise crítica das políticas de segurança da informação leve em consideração os resultados da análise crítica pela direção.

Convém que seja obtida a aprovação da direção para a política revisada.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002

- Cap. 6 = Organização da segurança da informação
- 6.1 = Organização interna
 - 6.1.1 = Responsabilidades e papéis pela segurança da informação
 - 6.1.2 = Segregação de funções
 - 6.1.3 = Contato com autoridades
 - 6.1.4 = Contato com grupos especiais
 - 6.1.5 = Segurança da informação no gerenciamento de projetos
- 6.2 = Dispositivos móveis e trabalho remoto
 - 6.2.1 = Política para o uso de dispositivo móvel
 - 6.2.2 = Trabalho remoto

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Organização da segurança da informação

Organização interna

Objetivo: Estabelecer uma estrutura de gerenciamento para iniciar e controlar a implementação e operação da segurança da informação dentro da organização.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Organização da segurança da informação

Organização interna

Responsabilidades e papéis pela segurança da informação: Controle

Convém que todas as responsabilidades pela segurança da informação sejam definidas e atribuídas.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Organização da segurança da informação

Organização interna

Responsabilidades e papéis pela segurança da informação: Diretrizes para implementação

Convém que a atribuição das responsabilidades pela segurança da informação seja feita em conformidade com as políticas de segurança da informação.

Convém que as responsabilidades pela proteção de cada ativo e pelo cumprimento de processos de segurança da informação específicos sejam claramente definidas.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Organização da segurança da informação

Organização interna

Responsabilidades e papéis pela segurança da informação: Diretrizes para implementação

Convém que as responsabilidades pelas atividades do gerenciamento dos riscos de segurança da informação e, em particular, pela aceitação dos riscos residuais sejam definidas.

Convém que as responsabilidades sejam complementadas, onde necessário, com orientações mais detalhadas para locais específicos e recursos de processamento da informação.

Convém que as responsabilidades locais para a proteção dos ativos e para realizar processos de segurança da informação específicos sejam definidas.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Organização da segurança da informação

Organização interna

Responsabilidades e papéis pela segurança da informação: Diretrizes para implementação

Indivíduos que receberam responsabilidades de segurança da informação podem delegar tarefas de segurança da informação para outros.

Todavia, convém que eles permaneçam responsáveis e determinem se quaisquer tarefas delegadas tenham sido corretamente executadas.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Organização da segurança da informação

Organização interna

Responsabilidades e papéis pela segurança da informação: Diretrizes para implementação

Convém que as áreas pelas quais as pessoas sejam responsáveis estejam claramente definidas; em particular, recomenda-se que os seguintes itens sejam cumpridos:

- a) convém que os ativos e os processos de segurança da informação sejam identificados e claramente definidos;
- b) convém que a entidade responsável por cada ativo ou processo de segurança da informação seja determinada e os detalhes dessa responsabilidade sejam documentados;
- c) convém que os níveis de autorização sejam claramente definidos e documentados;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Organização da segurança da informação

Organização interna

Responsabilidades e papéis pela segurança da informação: Diretrizes para implementação

Convém que as áreas pelas quais as pessoas sejam responsáveis estejam claramente definidas; em particular, recomenda-se que os seguintes itens sejam cumpridos:

- d) convém que as pessoas indicadas sejam competentes e capazes de cumprir com as responsabilidades pela segurança da informação e a elas seja dada a oportunidade de manter-se atualizada com os desenvolvimentos;
- e) convém que a coordenação e a visão global dos aspectos de segurança da informação na cadeia de suprimento sejam identificadas e documentadas.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Organização da segurança da informação

Organização interna

Responsabilidades e papéis pela segurança da informação: Informações adicionais

Muitas organizações atribuem a um gestor de segurança da informação a responsabilidade global pelo desenvolvimento e implementação da segurança da informação, e para apoiar a identificação de controles.

Entretanto, a responsabilidade por pesquisar e implementar os controles frequentemente permanecerá com os gestores individuais. Uma prática comum é a nomeação de um proprietário para cada ativo que, então, se torna responsável por sua proteção no dia a dia.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Organização da segurança da informação

Organização interna

Segregação de funções: Controle

Convém que funções conflitantes e áreas de responsabilidade sejam segregadas para reduzir as oportunidades de modificação não autorizada ou não intencional, ou uso indevido dos ativos da organização.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Organização da segurança da informação

Organização interna

Segregação de funções: Diretrizes para implementação

Convém que sejam tomados certos cuidados para impedir que uma única pessoa possa acessar, modificar ou usar ativos sem a devida autorização ou detecção.

Convém que o início de um evento seja separado de sua autorização.

Convém que a possibilidade de existência de conluíus seja considerada no projeto dos controles.

Pequenas organizações podem achar difícil realizar segregação de funções, mas convém que o princípio seja aplicado tanto quanto possível e praticável.

Convém que sempre que seja difícil segregar, outros controles como monitoração das atividades, trilha de auditoria e supervisão da gestão sejam considerados.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Organização da segurança da informação

Organização interna

Segregação de funções: Informações adicionais

Segregação de funções é um método para reduzir o risco de mau uso, acidental ou deliberado, dos ativos de uma organização.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Organização da segurança da informação

Organização interna

Contato com autoridades: Controle

Convém que contatos apropriados com autoridades relevantes sejam mantidos.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Organização da segurança da informação

Organização interna

Contato com autoridades: Diretrizes para implementação

Convém que a organização tenha procedimentos implementados que especifiquem quando e quais autoridades (por exemplo, obrigações legais, corpo de bombeiros, autoridades fiscalizadoras, organismos regulatórios) serão contatadas e como os incidentes de segurança da informação identificados serão reportados em tempo hábil (por exemplo, no caso de suspeita de que a lei foi violada).

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Organização da segurança da informação

Organização interna

Contato com autoridades: Informações adicionais

Organizações sob ataque da internet podem vir a necessitar que autoridades tomem providências contra a origem dos ataques.

Manter tais contatos pode ser um requisito para apoiar a gestão de incidentes de segurança da informação ou do processo de planejamento da contingência e da continuidade de negócio.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Organização da segurança da informação

Organização interna

Contato com autoridades: Informações adicionais

Contatos com organismos regulatórios também são úteis para antecipar-se e preparar-se para futuras alterações em leis ou regulamentos, que terão que ser implementados pela organização.

Contatos com outras autoridades incluem serviços de infraestrutura, serviços de emergência, fornecedores de energia, saúde e segurança, por exemplo, corpo de bombeiros (juntamente com continuidade de negócios), fornecedores de telecomunicações (juntamente com rotas de linha e disponibilidade) e fornecedores de água (juntamente com instalação de refrigeração para os equipamentos).

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Organização da segurança da informação

Organização interna

Contato com grupos especiais: Controle

Convém que contatos apropriados com grupos especiais, associações profissionais ou outros fóruns especializados em segurança da informação sejam mantidos.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Organização da segurança da informação

Organização interna

Contato com grupos especiais: Diretrizes para implementação

Convém que a associação a grupos especiais ou fóruns sejam considerados como forma de:

- a) ampliar o conhecimento sobre as melhores práticas e manter-se atualizado com as informações relevantes sobre segurança da informação;
- b) assegurar que o entendimento do ambiente de segurança da informação esteja atual e completo;
- c) receber previamente advertências de alertas, aconselhamentos e correções relativos a ataques e vulnerabilidades;
- d) conseguir acesso à consultoria especializada em segurança da informação;
- e) compartilhar e trocar informações sobre novas tecnologias, produtos, ameaças ou vulnerabilidades;
- f) prover relacionamentos adequados quando tratar com incidentes de segurança da informação.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Organização da segurança da informação

Organização interna

Contato com grupos especiais: Informações adicionais

Acordos de compartilhamento de informações podem ser estabelecidos para melhorar a cooperação e coordenação de assuntos de segurança da informação. Convém que tais acordos identifiquem requisitos para a proteção de informação confidencial.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Organização da segurança da informação

Organização interna

Segurança da informação no gerenciamento de projetos: Controle

Convém que a segurança da informação seja considerada no gerenciamento de projetos, independentemente do tipo do projeto.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Organização da segurança da informação

Organização interna

Segurança da informação no gerenciamento de projetos: Diretrizes para implementação

Convém que a segurança da informação seja integrada nos métodos de gerenciamento de projeto da organização para assegurar que os riscos de segurança da informação estejam identificados e considerados como parte de um projeto. Isto se aplica, de um modo geral, a qualquer projeto, independentemente do seu propósito, por exemplo, se é um projeto para um processo crítico do negócio, um processo de TI, de gerenciamento de recursos ou outro processo de apoio.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Organização da segurança da informação

Organização interna

Segurança da informação no gerenciamento de projetos: Diretrizes para implementação

Convém que os métodos de gerenciamento de projetos usados requeiram que: a) os objetivos de segurança da informação sejam contemplados nos objetivos do projeto; b) uma avaliação dos riscos de segurança da informação seja conduzida em estágios iniciais do projeto para identificar os controles que são necessários; c) a segurança da informação seja parte integrante de todas as fases da metodologia do projeto.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Organização da segurança da informação

Organização interna

Segurança da informação no gerenciamento de projetos: Informações adicionais

Convém que as questões de segurança da informação sejam consideradas e analisadas criticamente a intervalos planejados, em todos os projetos. Convém que as responsabilidades pela segurança da informação sejam definidas e alocadas para papéis específicos definidos dos métodos de gerenciamento de projeto.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Organização da segurança da informação

Dispositivos móveis e trabalho remoto

Objetivo: Garantir a segurança das informações no trabalho remoto e no uso de dispositivos móveis

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Organização da segurança da informação

Dispositivos móveis e trabalho remoto

Política para o uso de dispositivo móvel: Controle

Convém que uma política e medidas que apoiam a segurança da informação sejam adotadas para gerenciar os riscos decorrentes do uso de dispositivos móveis.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Organização da segurança da informação

Dispositivos móveis e trabalho remoto

Política para o uso de dispositivo móvel: Diretrizes para implementação

Convém que, quando se utilizam dispositivos móveis, cuidados especiais sejam tomados para assegurar que as informações do negócio não sejam comprometidas.

Convém que a política de dispositivos móveis leve em consideração os riscos de se trabalhar com esses dispositivos móveis em ambientes desprotegidos.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Organização da segurança da informação

Dispositivos móveis e trabalho remoto

Política para o uso de dispositivo móvel: Diretrizes para implementação

Convém que a política para uso de dispositivos móveis considere: a) registros dos dispositivos móveis; b) requisitos para a proteção física; c) restrições quanto à instalação de software; d) requisitos para as versões dos software e aplicações de patches; e) restrições para conexão aos serviços de informação; f) controle de acesso; g) técnicas criptográficas; h) proteção contra malware; i) desativação, bloqueio e exclusão de forma remota; j) backups; k) uso dos serviços web e aplicações web.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Organização da segurança da informação

Dispositivos móveis e trabalho remoto

Política para o uso de dispositivo móvel: Diretrizes para implementação

Convém que cuidados sejam tomados ao se utilizarem dispositivos móveis em locais públicos, salas de reuniões e outras áreas desprotegidas.

Convém que sejam estabelecidas proteções para evitar o acesso não autorizado ou a divulgação de informações armazenadas e processadas nesses dispositivos, por exemplo, usando técnicas de criptografia e obrigando o uso de autenticação por informação secreta.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Organização da segurança da informação

Dispositivos móveis e trabalho remoto

Política para o uso de dispositivo móvel: Diretrizes para implementação

Convém que os dispositivos móveis sejam também protegidos fisicamente contra roubo, especialmente quando deixados, por exemplo, em carros ou em outros meios de transporte, quartos de hotéis, centros de conferência e locais de reunião.

Convém que seja estabelecido um procedimento específico que leve em consideração requisitos legais, securitários e outros requisitos de segurança da organização para casos de furto, roubo ou perda de dispositivos móveis.

Convém que os dispositivos móveis que contêm informações importantes, sensíveis e/ou críticas para o negócio, não sejam deixados sem observação e, quando possível, estejam fisicamente trancados com o uso de travas especiais, para proteger esses dispositivos móveis.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Organização da segurança da informação

Dispositivos móveis e trabalho remoto

Política para o uso de dispositivo móvel: Diretrizes para implementação

Convém que seja programado treinamento para as pessoas que usam dispositivos móveis como forma de aumentar a conscientização quanto aos riscos adicionais decorrentes desta forma de trabalho, e quanto aos controles que recomendasse implementar.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Organização da segurança da informação

Dispositivos móveis e trabalho remoto

Política para o uso de dispositivo móvel: Diretrizes para implementação

Onde a política de dispositivos móveis permita o uso de dispositivos pessoais, convém que esta política e os controles de segurança relacionados também considerem: a) separação do uso do dispositivo para negócio e para fins pessoais, incluindo os software para apoiar esta separação e proteger os dados do negócio em um dispositivo privado; b) prover acesso às informações do negócio somente depois que os usuários assinarem o acordo de conhecimento das suas responsabilidades (quanto a proteção física, atualização do software, entre outros), renunciando direitos autorais dos dados do negócio, permitindo a exclusão remota dos dados pela organização no caso de furto, roubo ou perda do dispositivo móvel ou, ainda, quando não mais houver autorização para o uso dos serviços. Esta política precisa levar em consideração a legislação sobre privacidade.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Organização da segurança da informação

Dispositivos móveis e trabalho remoto

Política para o uso de dispositivo móvel: Informações adicionais

Conexões de dispositivos móveis sem fio são similares a outros tipos de conexões de rede, mas possuem diferenças importantes, as quais recomenda-se considerar na identificação dos controles. As diferenças típicas são: a) alguns protocolos de segurança sem fio são imaturos e possuem fraquezas conhecidas; b) informações armazenadas em dispositivos móveis podem não ser passíveis de cópia de segurança por conta de limitações da largura de banda da rede ou porque dispositivos móveis podem não estar conectados no momento em que a cópia de segurança for agendada.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Organização da segurança da informação

Dispositivos móveis e trabalho remoto

Política para o uso de dispositivo móvel: Informações adicionais

Dispositivos móveis geralmente compartilham funções comuns, por exemplo: rede, acesso à internet, e-mail e manuseio de arquivos, com uso de dispositivos fixos. Controles de segurança da informação para os dispositivos móveis geralmente consistem naqueles adotados para o uso de dispositivos fixos e naqueles para endereçar ameaças levantadas pelo seu uso fora das instalações da organização.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Organização da segurança da informação

Dispositivos móveis e trabalho remoto

Trabalho remoto: Controle

Convém que uma política e medidas que apoiam a segurança da informação sejam implementadas para proteger as informações acessadas, processadas ou armazenadas em locais de trabalho remoto.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Organização da segurança da informação

Dispositivos móveis e trabalho remoto

Trabalho remoto: Diretrizes para implementação

Convém que a organização que permita a atividade de trabalho remoto publique uma política que defina as condições e restrições para o uso do trabalho remoto. Onde considerados aplicáveis e permitidos por lei, convém que os seguintes pontos sejam considerados: a) a segurança física existente no local do trabalho remoto, levando-se em consideração a segurança física do prédio e o ambiente local; b) o ambiente físico proposto para o trabalho remoto;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Organização da segurança da informação

Dispositivos móveis e trabalho remoto

Trabalho remoto: Diretrizes para implementação

c) os requisitos de segurança nas comunicações, levando em consideração a necessidade do acesso remoto aos sistemas internos da organização, a sensibilidade da informação que será acessada e trafegada na linha de comunicação e a sensibilidade do sistema interno; d) o fornecimento de acesso virtual às estações de trabalho dos usuários, para prevenir o processamento e o armazenamento da informação em um equipamento de propriedade particular; e) a ameaça de acesso não autorizado à informação ou aos recursos de processamento da informação por outras pessoas que utilizam o local, por exemplo familiares e amigos;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Organização da segurança da informação

Dispositivos móveis e trabalho remoto

Trabalho remoto: Diretrizes para implementação

f) o uso de redes domésticas e requisitos ou restrições na configuração de serviços de rede sem fio; g) políticas e procedimentos para prevenir disputas relativas a direitos de propriedade intelectual desenvolvidas em equipamentos de propriedade particular; h) acesso a equipamentos de propriedade particular (para verificar a segurança da máquina ou durante uma investigação), o qual pode ser restringido por lei; i) acordos de licenciamento de software que podem tornar as organizações responsáveis pelo licenciamento do software cliente em estações de trabalho particulares de propriedade de funcionários, fornecedores ou partes externas; j) requisitos de firewall e proteção antivírus.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Organização da segurança da informação

Dispositivos móveis e trabalho remoto

Trabalho remoto: Diretrizes para implementação

Convém que as diretrizes e providências considerem: a) a provisão de equipamento e mobília apropriados às atividades de trabalho remoto, onde o uso de equipamentos de propriedade particular que não esteja sob controle da organização não seja permitido; b) uma definição do trabalho permitido, o período de trabalho, a classificação da informação que pode ser tratada e os sistemas internos e serviços que o usuário do trabalho remoto está autorizado a acessar; c) provisão de equipamento de comunicação apropriado, incluindo métodos para acesso remoto seguro; d) segurança física; e) regras e diretrizes sobre o acesso de familiares e visitantes ao equipamento e à informação; f) a provisão de suporte e manutenção de hardware e software; g) a provisão de seguro; h) os procedimentos para cópias de segurança e continuidade do negócio; i) auditoria e monitoramento da segurança; j) revogação de autoridade e direitos de acesso, e devolução do equipamento quando as atividades de trabalho remoto encerrarem.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Organização da segurança da informação

Dispositivos móveis e trabalho remoto

Trabalho remoto: Informações adicionais

Trabalho remoto refere-se a todas as formas de trabalho fora do escritório, incluindo ambientes de trabalho não tradicionais, como aqueles referidos: “ambientes de telecom”, “local de trabalho flexível”, “trabalho remoto” e “trabalho virtual”.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002

- Cap. 7 = Segurança em recursos humanos
 - 7.1 = Antes da contratação
 - 7.1.1 = Seleção
 - 7.1.2 = Termos e condições de contratação
 - 7.2 = Durante a contratação
 - 7.2.1 = Responsabilidades da Direção
 - 7.2.2 = Conscientização, educação e treinamento em segurança da informação
 - 7.2.3 = Processo disciplinar
 - 7.3 = Encerramento e mudança da contratação
 - 7.3.1 = Responsabilidades pelo encerramento ou mudança da contratação

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança em recursos humanos

Antes da contratação

Objetivo: Assegurar que funcionários e partes externas entendem as suas responsabilidades e estão em conformidade com os papéis para os quais eles foram selecionados.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança em recursos humanos

Antes da contratação

Seleção: Controle

Convém que verificações do histórico sejam realizadas para todos os candidatos a emprego, de acordo com a ética, regulamentações e leis relevantes, e seja proporcional aos requisitos do negócio, aos riscos percebidos e à classificação das informações a serem acessadas.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança em recursos humanos

Antes da contratação

Seleção: Diretrizes para implementação

Convém que as verificações levem em consideração toda a legislação pertinente relativa à privacidade, proteção da informação de identificação pessoal e do emprego e, onde permitido, incluam os seguintes itens: a) disponibilidade de referências de caráter satisfatórias, por exemplo uma profissional e uma pessoal; b) uma verificação (da exatidão e completeza) das informações do curriculum vitae do candidato; c) confirmação das qualificações acadêmicas e profissionais; d) verificação independente da identidade (passaporte ou documento similar); e) verificações mais detalhadas, como verificações de crédito ou verificações de registros criminais.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança em recursos humanos

Antes da contratação

Seleção: Diretrizes para implementação

Convém que, quando um indivíduo for contratado para desempenhar o papel de segurança da informação, a organização certifique-se de que o candidato: a) tem a competência necessária para executar o papel de segurança da informação; b) possa ser confiável para desempenhar o papel, especialmente se o papel for crítico para a organização. Onde um trabalho envolver pessoas, tanto por contratação como por promoção, que tenham acesso aos recursos de processamento da informação, em particular aquelas que tratam de informações sensíveis, como informações financeiras ou informações altamente confidenciais, convém que a organização faça verificações mais detalhadas.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança em recursos humanos

Antes da contratação

Seleção: Diretrizes para implementação

Convém que procedimentos definam critérios e limitações para as verificações de controle, por exemplo, quem está qualificado para selecionar as pessoas, e como, quando e por que as verificações de controle são realizadas. Convém que um processo de seleção também seja feito para fornecedores e partes externas. Nestes casos, convém que o acordo entre a organização e o prestador de serviços especifique as responsabilidades por conduzir e realizar a seleção, bem como os procedimentos de notificação que precisam ser seguidos no caso em que a seleção não tenha sido concluída ou se os resultados gerarem dúvidas ou preocupações.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança em recursos humanos

Antes da contratação

Seleção: Informações adicionais

Convém que as informações sobre todos os candidatos que estão sendo considerados para certas posições dentro da organização sejam levantadas e tratadas de acordo com a legislação apropriada existente na jurisdição pertinente. Dependendo da legislação aplicável, convém que os candidatos sejam previamente informados sobre as atividades de seleção.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança em recursos humanos

Antes da contratação

Termos e condições de contratação: Controle

Convém que as obrigações contratuais com funcionários e partes externas declarem a sua responsabilidade e as da organização para a segurança da informação.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança em recursos humanos

Antes da contratação

Termos e condições de contratação: Diretrizes para implementação

Convém que as obrigações contratuais para funcionários e partes externas reflitam as políticas para segurança da informação da organização, esclarecendo e declarando: a) que todos os funcionários, fornecedores e partes externas que tenham acesso a informações sensíveis assinem um termo de confidencialidade ou de não divulgação, antes de lhes ser dado o acesso aos recursos de processamento da informação; b) as responsabilidades legais e direitos dos funcionários e partes externas, e quaisquer outros usuários, por exemplo, com relação às leis de direitos autorais e legislação de proteção de dados; c) as responsabilidades pela classificação da informação e pelo gerenciamento dos ativos da organização, associados com a informação, com os recursos de processamento da informação e com os serviços de informação conduzidos pelos funcionários, fornecedores ou partes externas; d) as responsabilidades dos funcionários ou partes externas pelo tratamento da informação recebida de outras companhias ou partes interessadas; e) ações a serem tomadas no caso de o funcionário ou partes externas, desrespeitar os requisitos de segurança da informação da organização;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança em recursos humanos

Antes da contratação

Termos e condições de contratação: Diretrizes para implementação

Convém que os papéis e responsabilidades de segurança da informação sejam comunicados aos candidatos ao emprego durante o processo de pré-contratação.

Convém que a organização assegure que os funcionários ou partes externas concordem com os termos e condições relativas à segurança da informação, adequados à natureza e abrangência do acesso que eles terão aos ativos da organização, associados com os sistemas e serviços de informação. Onde apropriado, convém que as responsabilidades contidas nos termos e condições de contratação continuem por um período de tempo definido, após o término da contratação.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança em recursos humanos

Antes da contratação

Termos e condições de contratação: Informações adicionais

Um código de conduta pode ser usado para estabelecer as responsabilidades de segurança da informação do funcionário ou parte externa quanto à confidencialidade, proteção de dados, ética, uso apropriado dos equipamentos e recursos da organização, assim como as práticas respeitadas esperadas pela organização. Uma parte externa com a qual um fornecedor está vinculado pode ser solicitada a entrar nos acordos contratuais em nome do indivíduo contratado.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança em recursos humanos

Durante a contratação

Objetivo: Assegurar que os funcionários e partes externas estão conscientes e cumprem as suas responsabilidades pela segurança da informação.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança em recursos humanos

Durante a contratação

Responsabilidades da Direção: Controle

Convém que a Direção solicite a todos os funcionários e partes externas que pratiquem a segurança da informação de acordo com o estabelecido nas políticas e procedimentos da organização.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança em recursos humanos

Durante a contratação

Responsabilidades da Direção: Diretrizes para implementação

Convém que faça parte das responsabilidades da Direção assegurar que funcionários e partes externas: a) estejam adequadamente instruídos sobre as suas responsabilidades e papéis pela segurança da informação, antes de obter acesso às informações sensíveis ou aos sistemas de informação; b) recebam diretrizes que definam quais as expectativas sobre a segurança da informação de suas atividades dentro da organização; c) sejam motivados para cumprir com as políticas de segurança da informação da organização; d) atinjam um nível de conscientização sobre segurança da informação que seja relevante para os seus papéis e responsabilidades dentro da organização; e) cumpram com os termos e condições de trabalho, que incluam a política de segurança da informação da organização e métodos apropriados de trabalho; f) tenham as habilidades e qualificações apropriadas e sejam treinados regularmente; g) tenham disponível um canal de notificação, de forma anônima, para reportar violações nas políticas e procedimentos de segurança da informação. É recomendado que

a direção demonstre seu apoio às políticas, procedimentos e controles, e aja como tal, de forma exemplar.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança em recursos humanos

Durante a contratação

Responsabilidades da Direção: Informações adicionais

Se os funcionários e fornecedores não forem conscientizados das suas responsabilidades em segurança da informação, eles podem causar danos consideráveis para uma organização. Pessoal motivado pode ser mais confiável e causar menos incidentes de segurança da informação. Uma má gestão pode fazer com que o pessoal se sinta desvalorizado, resultando em impacto negativo na segurança da informação da organização. Por exemplo, uma má gestão pode levar a segurança da informação a ser negligenciada ou a um potencial mau uso dos ativos da organização.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança em recursos humanos

Durante a contratação

Conscientização, educação e treinamento em segurança da informação: Controle

Convém que todos os funcionários da organização e, onde pertinente, partes externas recebam treinamento, educação e conscientização apropriados, e as atualizações regulares das políticas e procedimentos organizacionais relevantes para as suas funções.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança em recursos humanos

Durante a contratação

Conscientização, educação e treinamento em segurança da informação: Diretrizes para implementação

Convém que um programa de conscientização em segurança da informação tenha por objetivo tornar os funcionários e, onde relevante, as partes externas conscientes das suas responsabilidades para a segurança da informação e os meios pelos quais essas responsabilidades são realizadas. Convém que um programa de conscientização em segurança da informação seja estabelecido alinhado com as políticas e procedimentos relevantes de segurança da informação da organização, levando em consideração as informações da organização a serem protegidas e os controles que foram implementados para proteger a informação. Convém que o programa de conscientização considere um número de atividades de conscientização, como campanhas (por exemplo, dia da segurança da informação) e a publicação de boletins ou folhetos.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança em recursos humanos

Durante a contratação

Conscientização, educação e treinamento em segurança da informação: Diretrizes para implementação

Convém que o programa de conscientização seja planejado levando em consideração os papéis a serem desempenhados na organização pelos funcionários e, onde relevante, as expectativas da organização quanto à conscientização das partes externas. Convém que as atividades do programa de conscientização sejam planejadas ao longo do tempo, preferencialmente de forma regular, de tal modo que as atividades sejam repetidas e contemplem novos funcionários e partes externas. Convém que o programa de conscientização também seja atualizado regularmente, de modo que ele permaneça alinhado com as políticas e os procedimentos da organização, e seja construído com base nas lições aprendidas dos incidentes de segurança da informação.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança em recursos humanos

Durante a contratação

Conscientização, educação e treinamento em segurança da informação: Diretrizes para implementação

Convém que o treinamento em conscientização seja realizado conforme requerido pelo programa de conscientização em segurança da informação da organização. Convém que o treinamento em conscientização use diferentes formas de apresentação, incluindo treinamento presencial, treinamento à distância, treinamento baseado em web, autodidata e outros. Convém que o treinamento e a educação em segurança da informação também contemplem aspectos gerais, como:

- a) declaração do comprometimento da direção com a segurança da informação em toda a organização; b) a necessidade de tornar conhecido e estar em conformidade com as obrigações e regras de segurança da informação aplicáveis, conforme definido nas políticas, normas, leis, regulamentações, contratos e acordos;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança em recursos humanos

Durante a contratação

Conscientização, educação e treinamento em segurança da informação: Diretrizes para implementação

Convém que o treinamento em conscientização seja realizado conforme requerido pelo programa de conscientização em segurança da informação da organização. Convém que o treinamento em conscientização use diferentes formas de apresentação, incluindo treinamento presencial, treinamento à distância, treinamento baseado em web, autodidata e outros. Convém que o treinamento e a educação em segurança da informação também contemplem aspectos gerais, como:

- c) responsabilidade pessoal por seus próprios atos e omissões, e compromissos gerais para manter segura ou para proteger a informação que pertença à organização e partes externas; d) procedimentos de segurança da informação básicos (como notificação de incidente de segurança da informação) e controles básicos (como, segurança da senha, controles contra malware e política de mesa limpa e tela limpa); e) pontos de contato e recursos para informações adicionais e orientações sobre questões de segurança da informação, incluindo materiais de treinamento e educação em segurança da informação.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança em recursos humanos

Durante a contratação

Conscientização, educação e treinamento em segurança da informação: Diretrizes para implementação

Convém que o treinamento e a educação em segurança da informação sejam realizados periodicamente. Treinamento e educação iniciais se aplicam àqueles que são transferidos para novas posições ou atribuições com requisitos de segurança da informação completamente diferentes, e não apenas aos novos iniciantes, e recomenda-se que sejam realizados antes de as pessoas assumirem os seus papéis.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança em recursos humanos

Durante a contratação

Conscientização, educação e treinamento em segurança da informação: Diretrizes para implementação

Convém que a organização desenvolva o programa de treinamento e educação com o objetivo de conduzir a educação e o treinamento de forma eficaz. Convém que o programa esteja alinhado com as políticas e procedimentos relevantes de segurança da informação da organização, levando em consideração as informações da organização a serem protegidas e os controles que foram implementados para proteger a informação. Convém que o programa considere diferentes formas de educação e treinamento, como palestras ou autoestudos.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança em recursos humanos

Durante a contratação

Conscientização, educação e treinamento em segurança da informação: Informações adicionais

Ao compor um programa de conscientização, é importante não focar apenas no “o que” e “como”, mas também no “por que”. É importante que os funcionários entendam os objetivos da segurança da informação e o impacto potencial, positivo e negativo, do seu próprio comportamento na organização. Conscientização, educação e treinamento podem ser parte de, ou conduzidos em colaboração com outras atividades de treinamento geral em TI ou treinamento geral em segurança.

Convém que conscientização, educação e atividades de treinamento sejam ajustáveis e relevantes aos papéis dos indivíduos, responsabilidades e habilidades. Uma avaliação do entendimento das pessoas pode ser conduzida no final do curso de conscientização, educação ou treinamento para testar a transferência de conhecimento.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança em recursos humanos

Durante a contratação

Processo disciplinar: Controle

Convém que exista um processo disciplinar formal, implantado e comunicado, para tomar ações contra funcionários que tenham cometido uma violação de segurança da informação.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança em recursos humanos

Durante a contratação

Processo disciplinar: Diretrizes para implementação

Convém que o processo disciplinar não seja iniciado sem uma verificação prévia de que a violação da segurança da informação realmente ocorreu.

Convém que o processo disciplinar formal assegure um tratamento justo e correto aos funcionários que sejam suspeitos de cometer violações de segurança da informação.

Convém que o processo disciplinar formal apresente uma resposta de forma gradual, que leve em consideração fatores como a natureza e a gravidade da violação e o seu impacto no negócio, se este é ou não o primeiro delito ou delito repetido, se o infrator foi ou não adequadamente treinado, as legislações relevantes, os contratos do negócio e outros fatores, conforme requerido.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança em recursos humanos

Durante a contratação

Processo disciplinar: Diretrizes para implementação

Convém que o processo disciplinar também seja usado como uma forma de dissuasão, para evitar que os funcionários e partes externas violem os procedimentos e as políticas de segurança da informação da organização, e quaisquer outras violações na segurança da informação. Violações deliberadas podem exigir ações imediatas.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança em recursos humanos

Durante a contratação

Processo disciplinar: Informações adicionais

O processo disciplinar pode também tornar-se uma motivação ou um incentivo, se recompensas positivas forem definidas por comportamento destacável no que se refere à segurança da informação.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança em recursos humanos

Encerramento e mudança da contratação

Objetivo: Proteger os interesses da organização como parte do processo de mudança ou encerramento da contratação.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança em recursos humanos

Encerramento e mudança da contratação

Responsabilidades pelo encerramento ou mudança da contratação: Controle

Convém que as responsabilidades e obrigações pela segurança da informação que permaneçam válidas após um encerramento ou mudança da contratação sejam definidas, comunicadas aos funcionários ou partes externas e cumpridas.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança em recursos humanos

Encerramento e mudança da contratação

Responsabilidades pelo encerramento ou mudança da contratação: Diretrizes para implementação

Convém que a comunicação de encerramento de atividades inclua requisitos de segurança da informação e responsabilidades legais existentes e, onde apropriado, responsabilidades contidas em quaisquer acordos de confidencialidade, e os termos e condições de trabalho que permaneçam por um período definido após o fim do trabalho do funcionário ou partes externas.

Convém que as responsabilidades e obrigações contidas nos contratos dos funcionários ou partes externas permaneçam válidas após o encerramento das atividades.

Convém que as mudanças de responsabilidades ou do trabalho sejam gerenciadas quando do encerramento da responsabilidade ou do trabalho atual, combinado com o início de novas responsabilidades ou trabalho.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança em recursos humanos

Encerramento e mudança da contratação

Responsabilidades pelo encerramento ou mudança da contratação: Informações adicionais

A função de recursos humanos é geralmente responsável por todo processo de demissão e trabalha junto com o gestor da pessoa que está saindo da empresa para gerir os aspectos relevantes dos procedimentos de segurança da informação. No caso de um prestador de serviço fornecido por uma parte externa, este processo é feito pela parte externa de acordo com o contrato entre a organização e a parte externa. Pode ser necessário informar funcionários, clientes ou fornecedores de alterações de pessoal e acordos operacionais.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002

Cap. 5

- Políticas de segurança da informação
- Orientação da direção para segurança da informação
 - Políticas para segurança da informação
- Análise crítica das políticas para segurança da informação

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002

Cap. 6

- **Organização da segurança da informação**
 - **Organização interna**
- **Responsabilidades e papéis pela segurança da informação**
 - **Segregação de funções**
 - **Contato com autoridades**
 - **Contato com grupos especiais**
- **Segurança da informação no gerenciamento de projetos**
 - **Dispositivos móveis e trabalho remoto**
 - **Política para o uso de dispositivo móvel**
 - **Trabalho remoto**

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002

Cap. 7

- **Segurança em recursos humanos**
 - **Antes da contratação**
 - **Seleção**
 - **Termos e condições de contratação**
 - **Durante a contratação**
 - **Responsabilidades da Direção**
- **Conscientização, educação e treinamento em segurança da informação**
 - **Processo disciplinar**
 - **Encerramento e mudança da contratação**
- **Responsabilidades pelo encerramento ou mudança da contratação**

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

- **TAREFA**

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002:

- Cap. 8 = Gestão de ativos
- 8.1 = Responsabilidade pelos ativos
 - 8.1.1 = Inventário dos ativos
 - 8.1.2 = Proprietário dos ativos
 - 8.1.3 = Uso aceitável dos ativos
 - 8.1.4 = Devolução de ativos
- 8.2 = Classificação da informação
 - 8.2.1 = Classificação da informação
 - 8.2.2 = Rótulos e tratamento da informação
 - 8.2.3 = Tratamento dos ativos
- 8.3 = Tratamento de mídias
 - 8.3.1 = Gerenciamento de mídias removíveis
 - 8.3.2 = Descarte de mídias
 - 8.3.3 = Transferência física de mídias

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Responsabilidade pelos ativos

Objetivo: Identificar os ativos da organização e definir as devidas responsabilidades pela proteção dos ativos.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Responsabilidade pelos ativos

Inventário dos ativos: Controle

Convém que os ativos associados à informação e aos recursos de processamento da informação sejam identificados, e um inventário destes ativos seja estruturado e mantido.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Responsabilidade pelos ativos

Inventário dos ativos: Diretrizes para implementação

Convém que a organização identifique os ativos relevantes no ciclo de vida da informação e documente a sua importância.

Convém que o ciclo de vida da informação inclua a criação, o processamento, o armazenamento, a transmissão, a exclusão e a sua destruição.

Convém que a documentação seja mantida em um inventário existente ou exclusivo, conforme apropriado.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Responsabilidade pelos ativos

Inventário dos ativos: Diretrizes para implementação

Convém que o inventário de ativos seja completo, atualizado, consistente e alinhado com outros inventários.

Convém que, para cada um dos ativos identificados, seja indicado um responsável e a classificação do ativo a ser identificado.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Responsabilidade pelos ativos

Inventário dos ativos: Informações adicionais

Os inventários de ativos ajudam a assegurar que a proteção efetiva ocorra e podem igualmente ser exigidos para outras finalidades, como saúde e segurança, razões de seguro ou financeiras (gestão de ativos).

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Responsabilidade pelos ativos

Proprietário dos ativos: Controle

Convém que os ativos mantidos no inventário tenham um proprietário.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Responsabilidade pelos ativos

Proprietário dos ativos: Diretrizes para implementação

Convém que as pessoas e outras entidades que tenham responsabilidades aprovadas pela direção para qualificar o ciclo de vida do ativo sejam designadas como o proprietário deste ativo.

Convém que seja implementado um processo para assegurar a atribuição, em tempo hábil, do proprietário de um ativo.

Convém que o proprietário seja designado quando os ativos são criados ou quando os ativos são transferidos para a organização.

Convém que o proprietário do ativo seja responsável pelo próprio gerenciamento deste ativo ao longo do seu ciclo de vida.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Responsabilidade pelos ativos

Proprietário dos ativos: Diretrizes para implementação

Convém que o proprietário do ativo: a) assegure que os ativos são inventariados; b) assegure que os ativos são adequadamente classificados e protegidos; c) defina e periodicamente analise criticamente as classificações e restrições ao acesso aos ativos importantes, levando em conta as políticas de controle de acesso aplicáveis; d) assegure um adequado tratamento quando o ativo é excluído ou destruído.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Responsabilidade pelos ativos

Proprietário dos ativos: Informações adicionais

O proprietário identificado pode ser um indivíduo ou uma entidade que aprovou a responsabilidade pela gestão, para controlar todo o ciclo de vida de um ativo. O proprietário identificado não tem necessariamente quaisquer direitos de propriedade sobre o ativo. As tarefas de rotina podem ser delegadas, por exemplo, para um custodiante cuidar dos ativos no dia a dia, mas a responsabilidade permanece com o proprietário. Em sistemas de informação complexos, pode ser útil definir grupos de ativos que atuem juntos para fornecer um serviço particular. Neste caso, o proprietário deste serviço é responsável pela entrega do serviço, incluindo a operação dos ativos envolvidos.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Responsabilidade pelos ativos

Uso aceitável dos ativos: Controle

Convém que regras para o uso aceitável das informações, dos ativos associados com a informação e dos recursos de processamento da informação sejam identificadas, documentadas e implementadas.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Responsabilidade pelos ativos

Uso aceitável dos ativos: Diretrizes para implementação

Convém que funcionários e partes externas que usam ou têm acesso aos ativos da organização estejam conscientes dos requisitos de segurança da informação dos ativos da organização, associados à informação e aos recursos de processamento da informação.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Responsabilidade pelos ativos

Uso aceitável dos ativos: Informações adicionais

Convém que eles sejam responsáveis pelo uso de qualquer recurso de processamento da informação e que tal uso seja realizado sob sua responsabilidade.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Responsabilidade pelos ativos

Devolução de ativos: Controle

Convém que todos os funcionários e partes externas devolvam todos os ativos da organização que estejam em sua posse, após o encerramento de suas atividades, do contrato ou acordo.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Responsabilidade pelos ativos

Devolução de ativos: Diretrizes para implementação

Convém que o processo de encerramento de atividades seja formalizado para contemplar a devolução de todos os equipamentos físico e eletrônico, de propriedade da organização.

Convém que no caso em que um funcionário ou partes externas comprem o equipamento da organização ou usem o seu próprio equipamento pessoal, procedimentos sejam adotados para assegurar que toda a informação relevante seja transferida para a organização e seja apagada de forma segura do equipamento.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Responsabilidade pelos ativos

Devolução de ativos: Diretrizes para implementação

Convém que, nos casos em que o funcionário ou partes externas tenha(m) conhecimento de que seu trabalho é importante para as atividades que são executadas, esta informação seja documentada e transferida para a organização.

Convém que, durante o período de encerramento, a organização monitore possíveis cópias de informações relevantes (por exemplo, propriedade intelectual) pelos funcionários ou partes externas que estão saindo da organização.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Responsabilidade pelos ativos

Devolução de ativos: Informações adicionais

Convém que, durante o período de encerramento, a organização monitore possíveis cópias de informações relevantes (por exemplo, propriedade intelectual) pelos funcionários ou partes externas que estão saindo da organização.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Classificação da informação

Objetivo: Assegurar que a informação receba um nível adequado de proteção, de acordo com a sua importância para a organização.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Classificação da informação

Classificação da informação: Controle

Convém que a informação seja classificada em termos do seu valor, requisitos legais, sensibilidade e criticidade para evitar modificação ou divulgação não autorizada.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Classificação da informação

Classificação da informação: Diretrizes para implementação

Convém que a classificação e os controles de proteção, associados à informação, levem em consideração as necessidades do negócio para compartilhar ou restringir a informação bem como os requisitos legais.

Convém que outros ativos, além dos ativos de informação, também sejam classificados de acordo com a classificação da informação armazenada, processada, manuseada ou protegida pelo ativo.

Convém que os proprietários de ativos de informação sejam responsáveis por sua classificação.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Classificação da informação

Classificação da informação: Diretrizes para implementação

Convém que o esquema de classificação inclua convenções para classificação e critérios para análise crítica da classificação ao longo do tempo.

Convém que o nível de proteção seja avaliado por meio da análise da confidencialidade, integridade e disponibilidade, e quaisquer requisitos considerados para a informação.

Convém que o esquema esteja alinhado com a política de controle de acesso.

Convém que a cada nível seja dado um nome que faça sentido no contexto do esquema de classificação.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Classificação da informação

Classificação da informação: Diretrizes para implementação

Convém que o esquema seja consistente em toda a organização, de forma que cada pessoa possa classificar a informação e os ativos relacionados da mesma forma, e tenha um entendimento comum dos requisitos de proteção e aplique a proteção apropriada.

Convém que a classificação seja incluída nos processos da organização e seja consistente e coerente em toda a organização.

Convém que os resultados da classificação indiquem o valor dos ativos em função da sua sensibilidade e criticidade para a organização, em termos da confidencialidade, integridade e disponibilidade.

Convém que os resultados da classificação sejam atualizados de acordo com as mudanças do seu valor, sensibilidade e criticidade ao longo do seu ciclo de vida.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Classificação da informação

Classificação da informação: Informações adicionais

A classificação fornece às pessoas que lidam com informações uma indicação concisa de como tratar e proteger a informação. A criação de grupos de informação com necessidades de proteção semelhantes e especificação dos procedimentos de segurança da informação que se aplicam a todas as informações de cada grupo é um facilitador. Esta abordagem reduz a necessidade de avaliação de risco e a customização personalizada de controles caso a caso

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Classificação da informação

Rótulos e tratamento da informação: Controle

Convém que um conjunto apropriado de procedimentos para rotular e tratar a informação seja desenvolvido e implementado de acordo com o esquema de classificação da informação adotado pela organização

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Classificação da informação

Rótulos e tratamento da informação: Diretrizes para implementação

Convém que procedimentos para a rotulagem da informação abranjam a informação e os seus ativos relacionados, nos formatos físico e eletrônico. A rotulagem pode refletir o esquema de classificação estabelecido.

Convém que os rótulos sejam facilmente reconhecidos.

Convém que o procedimento oriente sobre onde e como os rótulos devem ser colocados, levando-se em conta como a informação é acessada ou os ativos são manuseados, em função dos tipos de mídias.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Classificação da informação

Rótulos e tratamento da informação: Diretrizes para implementação

O procedimento pode definir uma situação onde a rotulagem é omitida, por exemplo, rotulagem de informação não confidencial, para reduzir a carga de trabalho.

Convém que os funcionários e partes externas estejam conscientes do procedimento de classificação da informação.

Convém que os resultados de sistemas que contém informações classificadas como críticas ou sensíveis tenham um nível de classificação apropriado.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Classificação da informação

Rótulos e tratamento da informação: Informações adicionais

A rotulagem de informações classificadas é um requisito-chave para acordos de compartilhamento de informações. Rótulos físicos e metadados são uma forma comum de rotulagem. A rotulagem de informação e de ativos relacionados pode às vezes ter efeitos negativos. Ativos classificados são mais fáceis de identificar e, conseqüentemente, roubados por pessoas internas ou externas.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Classificação da informação

Tratamento dos ativos: Controle

Convém que procedimentos para o tratamento dos ativos sejam desenvolvidos e implementados de acordo com o esquema de classificação da informação adotado pela organização.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Classificação da informação

Tratamento dos ativos: Diretrizes para implementação

Convém que procedimentos sejam estabelecidos para o tratamento, processamento, armazenamento e transmissão da informação, de acordo com a sua classificação.

Convém que os seguintes itens sejam considerados: a) restrições de acesso para apoiar os requisitos de proteção para cada nível de classificação; b) manutenção de um registro formal dos destinatários de ativos autorizados; c) proteção de cópias temporárias ou permanentes da informação a um nível consistente com a proteção da informação original; d) armazenamento dos ativos de TI de acordo com as especificações dos fabricantes; e) identificação eficaz de todas as cópias das mídias, para chamar a atenção dos destinatários autorizados.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Classificação da informação

Tratamento dos ativos: Diretrizes para implementação

O esquema de classificação usado na organização pode não ser equivalente aos esquemas usados por outras organizações, mesmo se os nomes dos níveis forem similares; adicionalmente, uma informação que transita entre organizações pode variar a sua classificação, dependendo do contexto da informação em cada organização, mesmo se os esquemas de classificação forem idênticos.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Classificação da informação

Tratamento dos ativos: Informações adicionais

Convém que acordos com outras organizações que incluam o compartilhamento de informação contemplem procedimento para identificar a classificação daquela informação e interpretar os rótulos de classificação de outras organizações.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Tratamento de mídias

Objetivo: Prevenir a divulgação não autorizada, modificação, remoção ou destruição da informação armazenada nas mídias.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Tratamento de mídias

Gerenciamento de mídias removíveis: Controle

Convém que existam procedimentos implementados para o gerenciamento de mídias removíveis, de acordo com o esquema de classificação adotado pela organização.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Tratamento de mídias

Gerenciamento de mídias removíveis: Diretrizes para implementação

Convém que as seguintes diretrizes para o gerenciamento de mídias removíveis sejam consideradas: a) quando não for mais necessário, o conteúdo de qualquer meio magnético reutilizável seja destruído, caso venha a ser retirado da organização; b) quando necessário e prático, seja requerida a autorização para remoção de qualquer mídia da organização e mantido o registro dessa remoção como trilha de auditoria; c) toda mídia seja guardada de forma segura em um ambiente protegido, de acordo com as especificações do fabricante; d) convém que sejam usadas, no caso em que a integridade ou confidencialidade dos dados sejam considerações importantes, técnicas de criptografia, para proteger os dados na mídia removível;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Tratamento de mídias

Gerenciamento de mídias removíveis: Diretrizes para implementação

Convém que as seguintes diretrizes para o gerenciamento de mídias removíveis sejam consideradas: e) para mitigar o risco de degradar a mídia enquanto os dados armazenados ainda são necessários, convém que os dados sejam transferidos para uma mídia nova antes de se tornarem ilegíveis; f) cópias múltiplas de dados valiosos sejam armazenadas em mídias separadas para reduzir riscos futuros de perda ou dano que ocorram por coincidência nessas mídias; g) as mídias removíveis sejam registradas para limitar a oportunidade de perda de dados; h) as unidades de mídias removíveis sejam habilitadas somente se houver uma necessidade do negócio; i) onde houver a necessidade para o uso de mídia removível, a transferência da informação contida na mídia seja monitorada.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Tratamento de mídias

Gerenciamento de mídias removíveis: Informações adicionais

Convém que procedimentos e níveis de autorização sejam documentados.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Tratamento de mídias

Descarte de mídias: Controle

Convém que as mídias sejam descartadas de forma segura, quando não forem mais necessárias, por meio de procedimentos formais.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Tratamento de mídias

Descarte de mídias: Diretrizes para implementação

Convém que procedimentos formais para o descarte seguro das mídias sejam definidos para minimizar o risco de vazamento de informações sensíveis para pessoas não autorizadas. Os procedimentos para o descarte seguro das mídias, contendo informações confidenciais, sejam proporcionais à sensibilidade das informações. Recomenda-se que os itens abaixo sejam considerados: a) convém que mídias contendo informações confidenciais sejam guardadas e destruídas de forma segura e protegida, como, por exemplo, através de incineração ou trituração, ou da remoção dos dados para uso por outra aplicação dentro da organização;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Tratamento de mídias

Descarte de mídias: Diretrizes para implementação

b) procedimentos sejam implementados para identificar os itens que requerem descarte seguro; c) pode ser mais fácil implementar a coleta e o descarte seguros de todas as mídias a serem inutilizadas do que tentar separar apenas aquelas contendo informações sensíveis; d) muitas organizações oferecem serviços de coleta e descarte de mídia; convém que sejam tomados cuidados na seleção de um fornecedor com experiência e controles adequados; e) convém que o descarte de itens sensíveis seja registrado, sempre que possível, para se manter uma trilha de auditoria.

Quando da acumulação de mídias para descarte, convém que seja levado em consideração o efeito proveniente do acúmulo, o que pode fazer com que uma grande quantidade de informação não sensível torne-se sensível.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Tratamento de mídias

Descarte de mídias: Informações adicionais

Equipamentos danificados contendo dados sensíveis podem exigir uma avaliação de riscos para determinar se é recomendado que os itens sejam destruídos fisicamente em vez de serem enviados para conserto ou descartados.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Tratamento de mídias

Transferência física de mídias: Controle

Convém que mídias contendo informações sejam protegidas contra acesso não autorizado, uso impróprio ou corrupção, durante o transporte.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Tratamento de mídias

Transferência física de mídias: Diretrizes para implementação

Convém que as seguintes recomendações sejam consideradas, para proteger as mídias que contêm informações, quando transportadas: a) o meio de transporte ou o serviço de mensageiros sejam confiáveis; b) seja definida uma relação de portadores autorizados em concordância com o gestor; c) seja estabelecido procedimento para a verificação da identificação dos transportadores;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Tratamento de mídias

Transferência física de mídias: Diretrizes para implementação

d) a embalagem seja suficiente para proteger o conteúdo contra qualquer dano físico, como os que podem ocorrer durante o transporte, e que seja feita de acordo com as especificações dos fabricantes (como no caso de software), por exemplo, protegendo contra fatores ambientais que possam reduzir a possibilidade de restauração dos dados, como a exposição ao calor, umidade ou campos eletromagnéticos; e) registros (logs) sejam guardados, identificando o conteúdo da mídia, a proteção aplicada, bem como os registros dos tempos de transferência no trânsito entre o custodiante e o destino final.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Gestão de ativos

Tratamento de mídias

Transferência física de mídias: Informações adicionais

Informações podem ser vulneráveis a acesso não autorizado, uso indevido ou corrupção durante o transporte físico, por exemplo, quando do envio de mídia através do serviço postal ou via correio. Neste controle, incluem-se mídias de documentos em papel. Quando a informação confidencial não é criptografada na mídia, convém que seja considerada a proteção física adicional desta mídia.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002:

- 9 = Controle de acesso
- 9.1 = Requisitos do negócio para controle de acesso
 - 9.1.1 = Política de controle de acesso
 - 9.1.2 = Acesso às redes e aos serviços de rede
- 9.2 = Gerenciamento de acesso do usuário
 - 9.2.1 = Registro e cancelamento de usuário
 - 9.2.2 = Provisionamento para acesso de usuário
 - 9.2.3 = Gerenciamento de direitos de acesso privilegiados
 - 9.2.4 = Gerenciamento da informação de autenticação secreta de usuários
 - 9.2.5 = Análise crítica dos direitos de acesso de usuário
 - 9.2.6 = Retirada ou ajuste dos direitos de acesso
- 9.3 = Responsabilidades dos usuários
 - 9.3.1 = Uso da informação de autenticação secreta
- 9.4 = Controle de acesso ao sistema e à aplicação
 - 9.4.1 = Restrição de acesso à informação
 - 9.4.2 = Procedimentos seguros de entrada no sistema (log-on)
 - 9.4.3 = Sistema de gerenciamento de senha
 - 9.4.4 = Uso de programas utilitários privilegiados
 - 9.4.5 = Controle de acesso ao código-fonte de programas

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Requisitos do negócio para controle de acesso

Objetivo: Limitar o acesso à informação e aos recursos de processamento da informação.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Requisitos do negócio para controle de acesso

Política de controle de acesso: Controle

Convém que uma política de controle de acesso seja estabelecida, documentada e analisada criticamente, baseada nos requisitos de segurança da informação e dos negócios.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Requisitos do negócio para controle de acesso

Política de controle de acesso: Diretrizes para implementação

Convém que os proprietários dos ativos determinem regras apropriadas do controle de acesso, direitos de acesso e restrições para papéis específicos dos usuários acessarem seus ativos, com o nível de detalhe e o rigor dos controles que reflitam os riscos de segurança da informação associados.

Convém que sejam considerados os controles de acesso lógico e físico de forma conjunta.

Convém que uma declaração nítida dos requisitos do negócio a serem atendidos pelo controle de acesso seja fornecida aos usuários e provedores de serviços.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Requisitos do negócio para controle de acesso

Política de controle de acesso: Diretrizes para implementação

Convém que a política leve em consideração os seguintes itens: a) requisitos de segurança de aplicações de negócios individuais; b) política para disseminação e autorização da informação, por exemplo, o princípio “necessidade de conhecer” e níveis de segurança e a classificação das informações (ver 8.2); c) consistência entre os direitos de acesso e as políticas de classificação da informação de sistemas e redes;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Requisitos do negócio para controle de acesso

Política de controle de acesso: Diretrizes para implementação

d) legislação pertinente e qualquer obrigação contratual relativa à proteção de acesso para dados ou serviços; e) gerenciamento de direitos de acesso em um ambiente distribuído e conectado à rede que reconhece todos os tipos de conexões disponíveis; f) segregação de funções de controle de acesso, por exemplo, pedido de acesso, autorização de acesso, administração de acesso; g) requisitos para autorização formal de pedidos de acesso; h) requisitos para análise crítica periódica de direitos de acesso; i) remoção de direitos de acesso; j) arquivo dos registros de todos os eventos significantes, relativos ao uso e gerenciamento das identidades do usuário e da informação de autenticação secreta; k) regras para o acesso privilegiado.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Requisitos do negócio para controle de acesso

Política de controle de acesso: Informações adicionais

Convém que sejam tomados cuidados na especificação de regras de controle de acesso quando se considerar o seguinte: a) estabelecer regra baseada na premissa de que “Tudo é proibido a menos que expressamente permitido” em lugar da regra mais fraca que “Tudo é permitido, a menos que expressamente proibido”; b) mudanças em rótulos de que são iniciadas automaticamente através de recursos de processamento da informação e aquelas iniciadas pela observação de um usuário; c) mudanças em permissões de usuário que são iniciadas automaticamente pelo sistema de informação e os que iniciaram por um administrador; d) regras que requerem aprovação específica antes de um decreto ou lei e as que não necessitam.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Requisitos do negócio para controle de acesso

Política de controle de acesso: Informações adicionais

Convém que as regras para controle de acesso sejam apoiadas por procedimentos formais e responsabilidades claramente definidas. As regras baseadas em controles de acesso são uma abordagem usada com sucesso por muitas organizações para relacionar os direitos de acesso com as atividades do negócio. Dois dos frequentes princípios que orientam a política de controle de acesso são: a) Necessidade de conhecer: você somente tem permissão para acessar informação que você necessita para desempenhar suas tarefas (tarefas e atribuições diferentes significam diferentes necessidades de conhecer e diferentes perfis de acesso); b) Necessidade de uso: você somente tem permissão para acessar os recursos de processamento da informação (equipamentos de TI, aplicações, procedimentos, salas) que você necessita para desempenhar a sua tarefa.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Requisitos do negócio para controle de acesso

Acesso às redes e aos serviços de rede: Controle

Convém que os usuários somente recebam acesso às redes e aos serviços de rede que tenham sido especificamente autorizados a usar.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Requisitos do negócio para controle de acesso

Acesso às redes e aos serviços de rede: Diretrizes para implementação

Convém que uma política seja formulada com relação ao uso de redes e serviços de rede.

Convém que esta política inclua: a) redes e serviços de redes que são permitidos de serem acessados; b) procedimentos de autorização para determinar quem tem permissão para acessar quais redes e serviços de redes; c) procedimentos e controles de gerenciamento para proteger o acesso a conexões e serviços de redes; d) os meios usados para acessar redes e serviços de rede (por exemplo, uso de VPN ou redes sem fio); e) requisitos de autenticação do usuário para acessar vários serviços de rede; f) monitoramento do uso dos serviços de rede. Convém que a política do uso de serviço de rede seja consistente com a política de controle de acesso da organização.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Requisitos do negócio para controle de acesso

Acesso às redes e aos serviços de rede: Informações adicionais

Conexões sem autorização e inseguras nos serviços de rede podem afetar toda a organização. Este controle é particularmente importante para conexões de redes sensíveis ou aplicações de negócios críticos ou para usuários em locais de alto risco, por exemplo, áreas públicas ou externas que estão fora da administração e controle da segurança da organização.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Gerenciamento de acesso do usuário

Objetivo: Assegurar acesso de usuário autorizado e prevenir acesso não autorizado a sistemas e serviços.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Gerenciamento de acesso do usuário

Registro e cancelamento de usuário: Controle

Convém que um processo formal de registro e cancelamento de usuário seja implementado para permitir atribuição dos direitos de acesso.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Gerenciamento de acesso do usuário

Registro e cancelamento de usuário: Diretrizes para implementação

Convém que o processo para gerenciar o ID de usuário inclua: a) o uso de um ID de usuário único, para permitir relacionar os usuários às suas responsabilidades e ações; convém que o uso compartilhado dos ID de usuário somente seja permitido onde eles são necessários por razões operacionais ou de negócios, e convém que seja aprovado e documentado;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Gerenciamento de acesso do usuário

Registro e cancelamento de usuário: Diretrizes para implementação

b) a imediata remoção ou desabilitação do ID de usuário que tenham deixado a organização; c) a remoção e identificação, de forma periódica, ou a desabilitação de usuários redundantes com ID; d) a garantia de que os ID de usuário redundante não seja emitido para outros usuários.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Gerenciamento de acesso do usuário

Provisionamento para acesso de usuário: Controle

Convém que um processo formal de provisionamento de acesso do usuário seja implementado para conceder ou revogar os direitos de acesso do usuário para todos os tipos de usuários em todos os tipos de sistemas e serviços.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Gerenciamento de acesso do usuário

Provisionamento para acesso de usuário: Diretrizes para implementação

Convém que o processo de provisionamento para atribuir ou revogar os direitos de acesso concedidos aos ID de usuário inclua: a) obtenção de autorização do proprietário do sistema ou do serviço da informação para o uso do serviço ou sistema da informação; aprovações separadas para os direitos de acesso da direção também podem ser recomendadas; b) verificação de que o nível de acesso concedido é apropriado às políticas de acesso e é consistente com outros requisitos, como segregação de funções; c) garantia de que os direitos de acesso não estão ativados (por exemplo, por provedores de serviços) antes que o procedimento de autorização esteja completo;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Gerenciamento de acesso do usuário

Provisionamento para acesso de usuário: Diretrizes para implementação

d) manutenção de um registro central de direitos de acesso concedido ao ID de usuário para acessar serviços e sistemas de informação; e) adaptação dos direitos de acesso dos usuários que tenham mudado de função ou de atividades, e imediata remoção ou bloqueio dos direitos de acesso dos usuários que deixaram a organização; f) direitos de acesso analisados criticamente a intervalos regulares com os proprietários dos serviços ou sistemas de informação

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Gerenciamento de acesso do usuário

Provisionamento para acesso de usuário: Informações adicionais

Convém que consideração seja dada para estabelecer as regras de acesso do usuário baseadas nos requisitos do negócio que resumam um número de direitos de acesso em um perfil típico de acesso do usuário. Solicitações de acesso e análises críticas (ver 9.2.4) são mais facilmente gerenciadas no nível de tais papéis do que no nível de direitos particulares.

Convém que consideração seja dada para incluir cláusulas nos contratos de pessoas e nos contratos de serviços, que especifiquem sanções no caso de tentativa de acesso não autorizado pelas pessoas ou pelas partes externas.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Gerenciamento de acesso do usuário

Gerenciamento de direitos de acesso privilegiados: Controle

Convém que a concessão e o uso de direitos de acesso privilegiado sejam restritos e controlados.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Gerenciamento de acesso do usuário

Gerenciamento de direitos de acesso privilegiados: Diretrizes para implementação

Convém que a alocação de direitos de acesso privilegiado seja controlada por meio de um processo de autorização formal, de acordo com a política de controle de acesso pertinente.

Convém que os seguintes passos sejam considerados: a) os direitos de acesso privilegiados, associados a cada sistema ou processo, por exemplo, sistema operacional, sistemas de gerenciamento de banco de dados de cada aplicação, e de categorias de usuários para os quais estes necessitam ser concedido, sejam identificados; b) os direitos de acesso privilegiado sejam concedidos a usuários conforme a necessidade de uso e com base em eventos alinhados com a política de controle de acesso, com base nos requisitos mínimos para sua função;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Gerenciamento de acesso do usuário

Gerenciamento de direitos de acesso privilegiados: Diretrizes para implementação

c) um processo de autorização e um registro de todos os privilégios concedidos sejam mantidos. Direitos de acesso privilegiados não sejam concedidos até que todo o processo de autorização esteja finalizado; d) requisitos para expirar os direitos de acesso privilegiado sejam definidos; e) os direitos de acesso privilegiados sejam atribuídos a um ID de usuário diferente daqueles usados nas atividades normais do negócio. As atividades normais do negócio não sejam desempenhadas usando ID privilegiados; f) as competências dos usuários com direitos de acesso privilegiado sejam analisadas criticamente a intervalos regulares, para verificar se eles estão alinhados com as suas obrigações;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Gerenciamento de acesso do usuário

Gerenciamento de direitos de acesso privilegiados: Diretrizes para implementação

g) procedimentos específicos sejam estabelecidos e mantidos para evitar o uso não autorizado dos ID de usuário de administrador genérico, de acordo com as capacidades de configuração dos sistemas; h) para os ID de usuário de administrador genéricos, a confidencialidade da informação de autenticação secreta seja mantida quando for compartilhada (por exemplo, mudanças de senhas com frequência e tão logo quanto possível, quando um usuário privilegiado deixa a organização ou muda de função, comunicação entre os usuários privilegiados por meio de mecanismos apropriados).

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Gerenciamento de acesso do usuário

Gerenciamento de direitos de acesso privilegiados: Informações adicionais

Uso inapropriado de privilégios de administrador de sistemas (qualquer característica ou recursos de sistemas de informação que habilitam usuários a exceder o controle de sistemas ou aplicações) pode ser um grande fator de contribuição para falhas ou violações de sistemas.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Gerenciamento de acesso do usuário

Gerenciamento da informação de autenticação secreta de usuários: Controle

Convém que a concessão de informação de autenticação secreta seja controlada por meio de um processo de gerenciamento formal.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Gerenciamento de acesso do usuário

Gerenciamento da informação de autenticação secreta de usuários: Diretrizes para implementação

Convém que o processo inclua os seguintes requisitos: a) solicitar aos usuários a assinatura de uma declaração, para manter a confidencialidade da informação de autenticação secreta e para manter as senhas de grupos de trabalho, exclusivamente com os membros do grupo; esta declaração assinada pode ser incluída nos termos e condições da contratação; b) garantir, onde os usuários necessitam manter suas próprias informações de autenticação secreta, que lhes seja fornecida uma informação de autenticação secreta temporária, a qual o usuário é obrigado a alterar no primeiro uso; c) estabelecer procedimentos para verificar a identidade de um usuário antes de fornecer uma informação de autenticação secreta, temporária, de substituição ou nova;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Gerenciamento de acesso do usuário

Gerenciamento da informação de autenticação secreta de usuários: Diretrizes para implementação

d) fornecer informação de autenticação secreta temporárias aos usuários de maneira segura; convém evitar o uso de mensagens de correio eletrônico de terceiros ou desprotegido (texto claro); e) informação de autenticação secreta temporária seja única para uma pessoa e não seja fácil de ser adivinhada; f) os usuários acusem o recebimento da informação de autenticação secreta; g) as informações de autenticações secretas padronizadas sejam alteradas logo após a instalação de sistemas ou software.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Gerenciamento de acesso do usuário

Gerenciamento da informação de autenticação secreta de usuários: Informações adicionais

Senhas são normalmente usadas como um tipo de informação de autenticação secreta, e são uma forma comum de verificar a identidade de um usuário. Outros tipos de informação de autenticação secreta são chaves criptográficas e outros dados armazenados em tokens (por exemplo, smart cards), que produzem códigos de autenticação.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Gerenciamento de acesso do usuário

Análise crítica dos direitos de acesso de usuário: Controle

Convém que os proprietários de ativos analisem criticamente os direitos de acesso dos usuários, a intervalos regulares.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Gerenciamento de acesso do usuário

Análise crítica dos direitos de acesso de usuário: Diretrizes para implementação

Convém que a análise crítica dos direitos de acesso considerem as seguintes orientações: a) os direitos de acesso de usuários sejam revisados em intervalos regulares e depois de quaisquer mudanças, como promoção, remanejamento ou encerramento do contrato;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Gerenciamento de acesso do usuário

Análise crítica dos direitos de acesso de usuário: Diretrizes para implementação

b) os direitos de acesso de usuários sejam analisados criticamente e realocados quando movidos de um tipo de atividade para outra na mesma organização; c) autorizações para direitos de acesso privilegiado especial sejam revisadas em intervalos mais frequentes; d) as alocações de privilégios sejam verificadas em intervalo de tempo regular para garantir que privilégios não autorizados não foram obtidos; e) as modificações para contas privilegiadas sejam registradas para análise crítica periódica.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Gerenciamento de acesso do usuário

Análise crítica dos direitos de acesso de usuário: Informações adicionais

Este controle compensa possíveis vulnerabilidades na execução dos controles.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Gerenciamento de acesso do usuário

Retirada ou ajuste dos direitos de acesso: Controle

Convém que os direitos de acesso de todos os funcionários e partes externas às informações e aos recursos de processamento da informação sejam retirados logo após o encerramento de suas atividades, contratos ou acordos, ou ajustados após a mudança destas atividades.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Gerenciamento de acesso do usuário

Retirada ou ajuste dos direitos de acesso: Diretrizes para implementação

Convém que, após o encerramento das atividades, os direitos de acesso da pessoa aos ativos associados com os sistemas de informação e serviços sejam removidos ou suspensos. Isto irá determinar se é necessário retirar os direitos de acesso. As mudanças de uma atividade podem refletir na retirada de todos os direitos de acesso que não foram aprovados para o novo trabalho.

Convém que os direitos de acesso que sejam retirados ou adaptados incluam o acesso lógico e físico. A remoção ou o ajuste pode ser feito por meio da remoção, revogação ou substituição de chaves, cartões de identificação, recursos de processamento da informação ou subscrições.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Gerenciamento de acesso do usuário

Retirada ou ajuste dos direitos de acesso: Diretrizes para implementação

Convém que qualquer documentação que identifique os direitos de acesso de funcionários e partes externas reflita a remoção ou o ajuste dos direitos de acesso. Caso o funcionário, fornecedor ou terceiro que esteja saindo tenha conhecimento de senhas de contas que permanecem ativas, convém que estas sejam alteradas após um encerramento das atividades, mudança do trabalho, contrato ou acordo.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Gerenciamento de acesso do usuário

Retirada ou ajuste dos direitos de acesso: Diretrizes para implementação

Convém que os direitos de acesso aos ativos de informação e aos recursos de processamento da informação sejam reduzidos ou retirados antes que a atividade se encerre ou altere, dependendo da avaliação de fatores de risco, como: a) se o encerramento da atividade ou a mudança é iniciada pelo funcionário, parte externa ou pelo gestor e a razão do encerramento da atividade; b) as responsabilidades atuais do funcionário, parte externa ou qualquer outro usuário; c) o valor dos ativos atualmente acessíveis.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Gerenciamento de acesso do usuário

Retirada ou ajuste dos direitos de acesso: Informações adicionais

Em certas circunstâncias os direitos de acesso podem ser alocados com base no que está sendo disponibilizado para mais pessoas do que as que estão saindo (funcionário, fornecedor ou terceiro), como, por exemplo, grupos de ID. Em tais casos, convém que as pessoas que estão saindo da organização sejam retiradas de quaisquer listas de grupos de acesso e que sejam tomadas providências para avisar aos outros funcionários, fornecedores e terceiros envolvidos para não mais compartilhar esta informação com a pessoa que está saindo.

Nos casos em que o encerramento da atividade seja da iniciativa do gestor, os funcionários, fornecedores ou terceiros descontentes podem deliberadamente corromper a informação ou sabotar os recursos de processamento da informação.

No caso de pessoas demitidas ou exoneradas, elas podem ser tentadas a coletar informações para uso futuro.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Responsabilidades dos usuários

Objetivo: Tornar os usuários responsáveis pela proteção das suas informações de autenticação.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Responsabilidades dos usuários

Uso da informação de autenticação secreta: Controle

Convém que os usuários sejam orientados a seguir as práticas da organização quanto ao uso da informação de autenticação secreta.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Responsabilidades dos usuários

Uso da informação de autenticação secreta: Diretrizes para implementação

Convém que todos os usuários sejam informados para: a) manter a confidencialidade da informação de autenticação secreta, garantindo que ela não seja divulgada para quaisquer outras partes, incluindo autoridades e lideranças; b) evitar manter anotada a informação de autenticação secreta (por exemplo, papel, arquivos ou dispositivos móveis), a menos que ela possa ser armazenada de forma segura e o método de armazenamento esteja aprovado (por exemplo, sistema de gerenciamento de senha); c) alterar a informação de autenticação secreta, sempre que existir qualquer indicação de possível comprometimento do sistema ou da própria senha;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Responsabilidades dos usuários

Uso da informação de autenticação secreta: Diretrizes para implementação

d) quando as senhas são usadas como informação de autenticação secreta, selecionar senhas de qualidade, com um tamanho mínimo, que sejam: 1) fáceis de lembrar; 2) não baseadas em nada que alguém facilmente possa adivinhar ou obter usando informações relativas à pessoa, por exemplo, nomes, números de telefone e datas de aniversário; 3) não vulneráveis a ataque de dicionário (por exemplo, não consistir em palavras inclusas no dicionário); 4) isentas de caracteres idênticos consecutivos, todos numéricos ou todos alfabéticos sucessivos; 5) caso a senha seja temporária, ela deve ser mudada no primeiro acesso (log-on);

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Responsabilidades dos usuários

Uso da informação de autenticação secreta: Diretrizes para implementação

e) não compartilhar a informação de autenticação secreta de usuários individuais; f) garantir adequada proteção de senhas quando as senhas são usadas como informação de autenticação secreta em procedimentos automáticos de acesso (log-on) e são armazenadas; g) não utilizar a mesma informação de autenticação secreta para uso com finalidades profissionais e pessoais.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Responsabilidades dos usuários

Uso da informação de autenticação secreta: Informações adicionais

O fornecimento de um Simple Sign On (SSO) ou outras ferramentas de gerenciamento de informação de autenticação secreta reduz o número de informação de autenticação secreta que os usuários são solicitados a proteger, aumentando dessa forma a eficácia desse controle. Entretanto, estas ferramentas podem também aumentar o impacto da revelação da informação de autenticação secreta.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Controle de acesso ao sistema e à aplicação

Objetivo: Prevenir o acesso não autorizado aos sistemas e aplicações

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Controle de acesso ao sistema e à aplicação

Restrição de acesso à informação: Controle

Convém que o acesso à informação e às funções dos sistemas de aplicações seja restrito, de acordo com a política de controle de acesso.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Controle de acesso ao sistema e à aplicação

Restrição de acesso à informação: Diretrizes para implementação

Convém que restrições para o acesso sejam baseadas nos requisitos das aplicações individuais do negócio e de acordo com a política de controle de acesso definida. Convém que os seguintes controles sejam considerados de forma a apoiar os requisitos de restrição de acesso: a) fornecer menus para controlar o acesso às funções dos sistemas de aplicação; b) controlar quais dados podem ser acessados por um usuário em particular; c) controlar os direitos de acesso dos usuários, por exemplo, ler, escrever, excluir e executar; d) controlar os direitos de acesso de outras aplicações; e) limitar a informação contida nas saídas;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Controle de acesso ao sistema e à aplicação

Restrição de acesso à informação: Informações adicionais

Prover controles de acesso lógico ou físico para o isolamento de aplicações sensíveis, dados de aplicação ou sistemas.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Controle de acesso ao sistema e à aplicação

Procedimentos seguros de entrada no sistema (log-on): Controle

Convém que, onde aplicável pela política de controle de acesso, o acesso aos sistemas e aplicações sejam controlados por um procedimento seguro de entrada no sistema (log-on).

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Controle de acesso ao sistema e à aplicação

Procedimentos seguros de entrada no sistema (log-on): Diretrizes para implementação

Convém que uma técnica de autenticação adequada seja escolhida para validar a identificação alegada de um usuário. Onde é requerida a verificação de identidade e uma forte autenticação, convém que métodos alternativos de autenticação para as senhas, como meios criptográficos, smart cards, tokens ou biometria, sejam usados.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Controle de acesso ao sistema e à aplicação

Procedimentos seguros de entrada no sistema (log-on): Diretrizes para implementação

Convém que o procedimento para entrada no sistema operacional seja configurado para minimizar a oportunidade de acessos não autorizados.

Convém que o procedimento de entrada (log-on) revele o mínimo de informações sobre o sistema ou aplicação, de forma a evitar o fornecimento de informações desnecessárias a um usuário não autorizado.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Controle de acesso ao sistema e à aplicação

Procedimentos seguros de entrada no sistema (log-on): Diretrizes para implementação

Convém que um bom procedimento de entrada no sistema (log-on): a) não mostre identificadores de sistema ou de aplicação até que o processo tenha sido concluído com sucesso; b) mostre um aviso geral informando que o computador seja acessado somente por usuários autorizados; c) não forneça mensagens de ajuda durante o procedimento de entrada (log-on) que poderiam auxiliar um usuário não autorizado; d) valide informações de entrada no sistema somente quando todos os dados de entrada estiverem completos. Caso ocorra uma condição de erro, o sistema não indique qual parte do dado de entrada está correta ou incorreta;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Controle de acesso ao sistema e à aplicação

Procedimentos seguros de entrada no sistema (log-on): Diretrizes para implementação

e) proteja contra tentativas forçadas de entrada no sistema (log-on); f) registre tentativas de acesso ao sistema, sem sucesso e bem-sucedida; g) comunique um evento de segurança caso uma tentativa potencial ou uma violação bem-sucedida de entrada no sistema (log-on) seja detectada; h) mostre as seguintes informações quando o procedimento de entrada no sistema (log-on) finalizar com sucesso: 1) data e hora da última entrada no sistema (log-on) com sucesso; 2) detalhes de qualquer tentativa sem sucesso de entrada no sistema (log-on) desde o último acesso com sucesso;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Controle de acesso ao sistema e à aplicação

Procedimentos seguros de entrada no sistema (log-on): Diretrizes para implementação

i) não mostre a senha que está sendo informada; j) não transmita senhas em texto claro pela rede; k) encerre sessões inativas após um período definido de inatividade, especialmente em locais de alto risco, como locais públicos, ou áreas externas ao gerenciamento de segurança da organização ou quando do uso de dispositivos móveis; l) restrinja os tempos de conexão para fornecer segurança adicional nas aplicações de alto risco e para reduzir a janela de oportunidade para acesso não autorizado.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Controle de acesso ao sistema e à aplicação

Procedimentos seguros de entrada no sistema (log-on): Informações adicionais

Senhas representam uma forma comum de prover identificação e autenticação com base no segredo de que somente o usuário é quem conhece. Isto também pode ser obtido com protocolos de autenticação e meios criptográficos.

Convém que a complexidade de autenticação do usuário seja apropriada para a classificação da informação a ser acessada.

Se as senhas forem transmitidas em texto claro durante o procedimento de entrada no sistema (log-on) pela rede, elas podem ser capturadas por um programa de sniffer de rede, instalado nela.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Controle de acesso ao sistema e à aplicação

Sistema de gerenciamento de senha: Controle

Convém que sistemas para gerenciamento de senhas sejam interativos e assegurem senhas de qualidade.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Controle de acesso ao sistema e à aplicação

Sistema de gerenciamento de senha: Diretrizes para implementação

Convém que o sistema de gerenciamento de senha: a) obrigue o uso individual de ID de usuário e senha para manter responsabilidades; b) permita que os usuários selecionem e modifiquem suas próprias senhas, incluindo um procedimento de confirmação para evitar erros; c) obrigue a escolha de senhas de qualidade; d) obrigue os usuários a mudarem as suas senhas temporárias no primeiro acesso ao sistema; e) force as mudanças de senha a intervalos regulares, conforme necessário; f) mantenha um registro das senhas anteriores utilizadas e bloqueie a reutilização; g) não mostre as senhas na tela quando forem digitadas; h) armazene os arquivos de senha separadamente dos dados do sistema da aplicação; i) armazene e transmita as senhas de forma protegida.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Controle de acesso ao sistema e à aplicação

Sistema de gerenciamento de senha: Informações adicionais

Algumas aplicações requerem que senhas de usuário sejam atribuídas por uma autoridade independente.

Na maioria dos casos, as senhas são selecionadas e mantidas pelos usuários.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Controle de acesso ao sistema e à aplicação

Uso de programas utilitários privilegiados: Controle

Convém que o uso de programas utilitários que podem ser capazes de sobrepor os controles dos sistemas e aplicações seja restrito e estritamente controlado.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Controle de acesso ao sistema e à aplicação

Uso de programas utilitários privilegiados: Diretrizes para implementação

Convém que as seguintes diretrizes para o uso de utilitários de programa que possam ser capazes de sobrepor os controles dos sistemas e as aplicações sejam consideradas: a) uso de procedimentos de identificação, autenticação e autorização para programas utilitários de sistema;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Controle de acesso ao sistema e à aplicação

Uso de programas utilitários privilegiados: Diretrizes para implementação

b) segregação de programas utilitários dos software de aplicação; c) limitação do uso de programas utilitários a um número mínimo de usuários confiáveis e autorizados; d) autorização para uso de programas utilitários não previstos; e) limitação da disponibilidade dos programas utilitários, por exemplo para a duração de uma modificação autorizada; f) registro de todo o uso de programas utilitários; g) definição e documentação dos níveis de autorização para os programas utilitários; h) remoção ou desabilitação de todos os programas utilitários desnecessários; i) não deixar programas utilitários disponíveis para usuários que têm acesso às aplicações nos sistemas onde a segregação de funções é requerida.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Controle de acesso ao sistema e à aplicação

Uso de programas utilitários privilegiados: Informações adicionais

A maioria das instalações de computadores tem um ou mais programas utilitários que podem ser capazes de sobrepor os controles dos sistemas e aplicações.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Controle de acesso ao sistema e à aplicação

Controle de acesso ao código-fonte de programas: Controle

Convém que o acesso ao código-fonte de programa seja restrito.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Controle de acesso ao sistema e à aplicação

Controle de acesso ao código-fonte de programas: Diretrizes para implementação

Convém que o acesso ao código-fonte de programas e de itens associados (como desenhos, especificações, planos de verificação e de validação) seja estritamente controlado, com a finalidade de prevenir a introdução de funcionalidade não autorizada e para evitar mudanças não intencionais, bem como para manter a confidencialidade de propriedade intelectual valiosa.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Controle de acesso ao sistema e à aplicação

Controle de acesso ao código-fonte de programas: Diretrizes para implementação

Para os códigos-fonte de programas, este controle pode ser obtido com a guarda centralizada do código, de preferência utilizando bibliotecas de programa-fonte. É conveniente que as seguintes orientações sejam consideradas para o controle de acesso às bibliotecas de programa-fonte, com a finalidade de reduzir o risco de corrupção de programas de computador:

- a) quando possível, convém que seja evitado manter as bibliotecas de programa-fonte no mesmo ambiente dos sistemas operacionais; b) convém que seja implementado o controle do código-fonte de programa e das bibliotecas de programa-fonte, conforme procedimentos estabelecidos; c) convém que o pessoal de suporte não tenha acesso irrestrito às bibliotecas de programa-fonte; d) convém que a atualização das bibliotecas de programa-fonte e itens associados, e a entrega de fontes de programas a programadores sejam apenas efetuadas após o recebimento da autorização pertinente;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Controle de acesso ao sistema e à aplicação

Controle de acesso ao código-fonte de programas: Diretrizes para implementação

e) convém que as listagens dos programas sejam mantidas em um ambiente seguro; f) convém que seja mantido um registro de auditoria de todos os acessos a código-fonte de programas; g) convém que a manutenção e a cópia das bibliotecas de programa-fonte estejam sujeitas a procedimentos estritos de controles de mudanças.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Controle de acesso

Controle de acesso ao sistema e à aplicação

Controle de acesso ao código-fonte de programas: Informações adicionais

Se pretende-se que o código do programa-fonte seja publicado, convém que sejam considerados controles adicionais, para ajudar a garantir a sua integridade (por exemplo, assinatura digital).

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002

Cap. 10 - Criptografia

10.1 - Controles criptográficos

10.1.1 - Política para o uso de controles criptográficos

10.1.2 - Gerenciamento de chaves

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Criptografia

Controles criptográficos

Objetivo: Assegurar o uso efetivo e adequado da criptografia para proteger a confidencialidade, autenticidade e/ou a integridade da informação.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Criptografia

Controles criptográficos

Política para o uso de controles criptográficos: Controle

Convém que seja desenvolvida e implementada uma política sobre o uso de controles criptográficos para a proteção da informação.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Criptografia

Controles criptográficos

Política para o uso de controles criptográficos: Diretrizes para implementação

Quando do desenvolvimento de uma política para criptografia, convém que sejam considerados:

- a) a abordagem da Direção quanto ao uso de controles criptográficos em toda a organização, incluindo os princípios gerais sob os quais as informações de negócio sejam protegidas;
- b) a identificação do nível requerido de proteção com base em uma avaliação de risco, levando em consideração o tipo, a força e a qualidade do algoritmo de criptografia requerido;
- c) o uso de criptografia para a proteção de informações sensíveis transportadas em dispositivos móveis, mídias removíveis ou através de linhas de comunicação;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Criptografia

Controles criptográficos

Política para o uso de controles criptográficos: Diretrizes para implementação

- d) a abordagem do gerenciamento de chaves, incluindo métodos para lidar com a proteção das chaves criptográficas e a recuperação de informações cifradas, no caso de chaves perdidas, comprometidas ou danificadas;
- e) papéis e responsabilidades, por exemplo, de quem for responsável: 1) pela implementação da política; 2) pelo gerenciamento de chaves, incluindo sua geração;
- f) os padrões a serem adotados para a eficaz implementação ao longo de toda a organização (qual solução é usada para quais processos de negócios);
- g) o impacto do uso de informações cifradas em controles que dependem da inspeção de conteúdos (por exemplo, detecção de malware).

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Criptografia

Controles criptográficos

Política para o uso de controles criptográficos: Diretrizes para implementação

Convém que sejam consideradas na implementação da política criptográfica da organização as leis ou regulamentações e restrições nacionais aplicáveis ao uso de técnicas criptográficas, nas diferentes partes do mundo, e as questões relativas ao fluxo transfronteiras de informações cifradas (ver 18.1.5).

Controles criptográficos podem ser usados para alcançar diferentes objetivos de segurança da informação, como, por exemplo:

a) confidencialidade: usando a criptografia da informação para proteger informações sensíveis ou críticas, armazenadas ou transmitidas;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Criptografia

Controles criptográficos

Política para o uso de controles criptográficos: Diretrizes para implementação

- b) integridade/autenticidade: usando assinaturas digitais ou códigos de autenticação de mensagens para verificar a autenticidade ou integridade de informações sensíveis ou críticas, armazenadas ou transmitidas;
- c) não repúdio: usando técnicas de criptografia para obter evidência da ocorrência ou não ocorrência de um evento ou ação;
- d) autenticação: usando técnicas criptográficas para autenticar usuários e outras camadas sistêmicas que requeiram acesso para transações com usuários de sistemas, entidades e recursos.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Criptografia

Controles criptográficos

Política para o uso de controles criptográficos: Informações adicionais

Convém que a tomada de decisão quanto a uma solução de criptografia ser apropriada seja vista como parte de processos mais amplos de avaliação de riscos e seleção de controles. Essa avaliação pode, então, ser usada para determinar se um controle criptográfico é apropriado, que tipo de controle convém ser aplicado e para qual propósito e processos de negócio.

Uma política sobre o uso de controles criptográficos é necessária para maximizar os benefícios, minimizar os riscos do uso de técnicas criptográficas e para evitar o uso incorreto ou inapropriado.

Convém que seja buscada a opinião de um especialista para identificar os controles criptográficos adequados para atender aos objetivos da política de segurança da informação.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Criptografia

Controles criptográficos

Gerenciamento de chaves: Controle

Convém que uma política sobre o uso, proteção e tempo de vida das chaves criptográficas seja desenvolvida e implementada ao longo de todo o seu ciclo de vida.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Criptografia

Controles criptográficos

Gerenciamento de chaves: Diretrizes para implementação

Convém que a política inclua requisitos para o gerenciamento de chaves criptográficas ao longo de todo o seu ciclo de vida, incluindo a geração, armazenamento, arquivo, recuperação, distribuição, retirada e destruição das chaves.

Convém que algoritmos criptográficos, tamanho de chaves e práticas usuais sejam selecionados de acordo com as melhores práticas. A gestão de chaves apropriada requer processos seguros para a geração, armazenagem, arquivo, recuperação, distribuição, retirada e destruição das chaves.

Convém que todas as chaves criptográficas sejam protegidas contra modificação e perda. Adicionalmente, chaves secretas e privadas necessitam de proteção contra o uso ou a divulgação não autorizada. É recomendável que os equipamentos utilizados para gerar, armazenar e guardar as chaves sejam fisicamente protegidos.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Criptografia

Controles criptográficos

Gerenciamento de chaves: Diretrizes para implementação

Convém que um sistema de gerenciamento de chaves seja baseado em um conjunto estabelecido de normas, procedimentos e métodos seguros para:

- a) gerar chaves para diferentes sistemas criptográficos e diferentes aplicações;
- b) gerar e obter certificados de chaves públicas;
- c) distribuir chaves para os usuários devidos, incluindo a forma como as chaves são ativadas, quando recebidas;
- d) armazenar chaves, incluindo a forma como os usuários autorizados obtêm acesso a elas;
- e) mudar ou atualizar chaves, incluindo regras para quando as chaves são mudadas e como isto deve ser conduzido;
- f) lidar com chaves comprometidas;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Criptografia

Controles criptográficos

Gerenciamento de chaves: Diretrizes para implementação

- g) revogar chaves, incluindo regras de como elas são retiradas ou desativadas, por exemplo, quando chaves tiverem sido comprometidas ou quando um usuário deixa a organização (é recomendável também, neste caso, que as chaves sejam arquivadas);
- h) recuperar chaves perdidas ou corrompidas;
- i) realizar cópias de segurança ou arquivar as chaves;
- j) destruir chaves;
- k) manter registro e auditoria das atividades relacionadas ao gerenciamento de chaves;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Criptografia

Controles criptográficos

Gerenciamento de chaves: Diretrizes para implementação

Para reduzir a probabilidade de comprometimento, convém que as datas de ativação e desativação de chaves sejam definidas de forma que possam ser utilizadas apenas por um período de tempo definido na política de gerenciamento de chaves. Além do gerenciamento seguro de chaves secretas e privadas, convém que a autenticidade de chaves públicas seja considerada.

Este processo de autenticação pode ser conduzido utilizando-se certificados de chaves públicas que são normalmente emitidos por uma autoridade certificadora, a qual recomenda-se que seja uma organização reconhecida, com controles adequados e procedimentos implantados com o objetivo de garantir o requerido nível de confiança

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Criptografia

Controles criptográficos

Gerenciamento de chaves: Diretrizes para implementação

Convém que os conteúdos dos acordos de nível de serviço ou dos contratos com fornecedores externos de serviços criptográficos, como, por exemplo, com uma autoridade certificadora, cubra aspectos como responsabilidades, confiabilidade dos serviços e tempos de resposta para a execução dos serviços contratados (ver 15.2).

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Criptografia

Controles criptográficos

Gerenciamento de chaves: Informações adicionais

A gestão de chaves criptográficas é essencial para o uso eficaz de técnicas criptográficas. A ISO/IEC 11.770 fornece informação adicional sobre a gestão de chaves. Técnicas criptográficas podem ser também utilizadas para proteger chaves criptográficas.

Pode ser necessário o estabelecimento de procedimentos para o manuseio de solicitações legais para acesso a chaves criptográficas, por exemplo, a disponibilização de informação cifrada pode ser requerida em sua forma decifrada para uso como evidência em um processo judicial.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002

Cap. 11 - Segurança física e do ambiente

11.1 - Áreas seguras

11.1.1 - Perímetro de segurança física

11.1.2 - Controles de entrada física

11.1.3 - Segurança em escritórios, salas e instalações

11.1.4 - Proteção contra ameaças externas e do meio ambiente

11.1.5 - Trabalhando em áreas seguras

11.1.6 - Áreas de entrega e de carregamento

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Áreas seguras

Objetivo: Prevenir o acesso físico não autorizado, danos e interferências com os recursos de processamento das informações e nas informações da organização.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Áreas seguras

Perímetro de segurança física: Controle

Convém que perímetros de segurança sejam definidos e usados para proteger tanto as instalações de processamento da informação como as áreas que contenham informações críticas ou sensíveis.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Áreas seguras

Perímetro de segurança física: Diretrizes para implementação

Convém que as seguintes diretrizes sejam consideradas e implementadas, onde apropriado, para os perímetros de segurança física:

- a) convém que os perímetros de segurança sejam claramente definidos e que a localização e a capacidade de resistência de cada perímetro dependam dos requisitos de segurança dos ativos existentes no interior do perímetro e dos resultados da avaliação de riscos;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Áreas seguras

Perímetro de segurança física: Diretrizes para implementação

b) convém que os perímetros de um edifício ou de um local que contenha as instalações de processamento da informação sejam fisicamente sólidos (ou seja, não é recomendável que o perímetro tenha brechas nem pontos onde poderia ocorrer facilmente uma invasão); convém que as paredes externas do local sejam de construção robusta e todas as portas externas sejam adequadamente protegidas contra acesso não autorizado por meio de mecanismos de controle (por exemplo, barras, alarmes, fechaduras); as portas e janelas sejam trancadas quando estiverem sem monitoração e uma proteção externa para as janelas seja considerada, principalmente para as que estiverem situadas no andar térreo;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Áreas seguras

Perímetro de segurança física: Diretrizes para implementação

- c) convém que seja implantada uma área de recepção, ou um outro meio para controlar o acesso físico ao local ou ao edifício; convém que o acesso aos locais ou edifícios fique restrito somente ao pessoal autorizado;
- d) convém que sejam construídas barreiras físicas, onde aplicável, para impedir o acesso físico não autorizado e a contaminação do meio ambiente;
- e) convém que todas as portas corta-fogo do perímetro de segurança sejam providas de alarme, monitoradas e testadas juntamente com as paredes, para estabelecer o nível de resistência exigido, de acordo com normas regionais, nacionais e internacionais aceitáveis; convém que elas funcionem de acordo com os códigos locais de prevenção de incêndios e prevenção de falhas;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Áreas seguras

Perímetro de segurança física: Diretrizes para implementação

f) convém que sistemas adequados de detecção de intrusos, de acordo com normas regionais, nacionais e internacionais, sejam instalados e testados em intervalos regulares, e cubram todas as portas externas e janelas acessíveis; convém que as áreas não ocupadas sejam protegidas por alarmes o tempo todo; também é recomendável que seja dada proteção a outras áreas, por exemplo, salas de computadores ou salas de comunicações;

g) convém que as instalações de processamento da informação gerenciadas pela organização fiquem fisicamente separadas daquelas que são gerenciadas por partes externas.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Áreas seguras

Perímetro de segurança física: Informações adicionais

Pode-se obter proteção física criando uma ou mais barreiras físicas ao redor das instalações e dos recursos de processamento da informação da organização. O uso de barreiras múltiplas proporciona uma proteção adicional, uma vez que neste caso a falha de uma das barreiras não significa que a segurança fique comprometida imediatamente. Uma área segura pode ser um escritório trancado ou um conjunto de salas rodeado por uma barreira física interna contínua de segurança. Pode haver necessidade de barreiras e perímetros adicionais para o controle do acesso físico, quando existem áreas com requisitos diferentes de segurança dentro do perímetro de segurança.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Áreas seguras

Perímetro de segurança física: Informações adicionais

Convém que sejam tomadas precauções especiais para a segurança do acesso físico no caso de edifícios que alojam diversas organizações. Convém que a aplicação de controles físicos, especialmente para as áreas seguras, seja adaptada para as circunstâncias técnicas e econômicas da organização, como definido na avaliação de riscos.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Áreas seguras

Controles de entrada física: Controle

Convém que as áreas seguras sejam protegidas por controles apropriados de entrada para assegurar que somente pessoas autorizadas tenham acesso permitido.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Áreas seguras

Controles de entrada física: Diretrizes para implementação:

Convém que sejam levadas em consideração as seguintes diretrizes: a) convém que a data e a hora da entrada e saída de visitantes sejam registradas, e todos os visitantes sejam supervisionados, a não ser que o seu acesso tenha sido previamente aprovado; convém que as permissões de acesso só sejam concedidas para finalidades específicas e autorizadas, e sejam emitidas com instruções sobre os requisitos de segurança da área e os procedimentos de emergência.

Convém que a identidade dos visitantes seja autenticada por meios apropriados; b) convém que o acesso às áreas em que são processadas ou armazenadas informações sensíveis seja restrito apenas ao pessoal autorizado pela implementação de controles de acesso apropriados, por exemplo, mecanismos de autenticação de dois fatores, como, cartões de controle de acesso e PIN (personal identification number);

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Áreas seguras

Controles de entrada física: Diretrizes para implementação:

c) convém que uma trilha de auditoria eletrônica ou um livro de registro físico de todos os acessos seja mantida e monitorada de forma segura; d) convém que seja exigido que todos os funcionários, fornecedores e partes externas, e todos os visitantes, tenham alguma forma visível de identificação e que eles avisem imediatamente ao pessoal de segurança, caso encontrem visitantes não acompanhados ou qualquer pessoa que não esteja usando uma identificação visível; e) às partes externas que realizam serviços de suporte, convém que seja concedido acesso restrito às áreas seguras ou as instalações de processamento da informação sensíveis, somente quando necessário; convém que este acesso seja autorizado e monitorado;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Áreas seguras

Controles de entrada física: Informações adicionais

Convém que os direitos de acesso a áreas seguras sejam revistos e atualizados em intervalos regulares, e revogados quando necessário (ver 9.2.5 e 9.2.6).

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Áreas seguras

Segurança em escritórios, salas e instalações: Controle

Convém que seja projetada e aplicada segurança física para escritórios, salas e instalações.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Áreas seguras

Segurança em escritórios, salas e instalações: Diretrizes para implementação

Convém que sejam levadas em consideração as seguintes diretrizes para proteger escritórios, salas e instalações: a) convém que as instalações-chave sejam localizadas de maneira a evitar o acesso do público; b) quando for aplicável, convém que os edifícios sejam discretos com a menor indicação possível da sua finalidade, sem letreiros evidentes, fora ou dentro do edifício, que identifiquem a presença de atividades de processamento de informações; c) convém que as instalações sejam projetadas para evitar que as informações confidenciais ou as atividades sejam visíveis e possam ser ouvidas da parte externa.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Áreas seguras

Segurança em escritórios, salas e instalações: Informações adicionais

Convém que proteção eletromagnética também seja considerada, conforme apropriado;

Convém que as listas de funcionários e guias telefônicos internos, que identifiquem a localização das instalações que processam informações sensíveis, não sejam facilmente acessíveis a qualquer pessoa não autorizada.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Áreas seguras

Proteção contra ameaças externas e do meio ambiente: Controle

Convém que seja projetada e aplicada proteção física contra desastres naturais, ataques maliciosos ou acidentes.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Áreas seguras

Proteção contra ameaças externas e do meio ambiente: Diretrizes para implementação

Convém que orientações de especialistas sejam obtidas sobre como evitar danos oriundos de fogo, inundação, terremoto, explosão, manifestações civis e outras formas de desastre natural ou provocado pela natureza.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Áreas seguras

Proteção contra ameaças externas e do meio ambiente: Informações adicionais

Convém que os direitos de acesso a áreas seguras sejam revistos e atualizados em intervalos regulares.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Áreas seguras

Trabalhando em áreas seguras: Controle

Convém que sejam projetados e aplicados procedimentos para o trabalho em áreas seguras.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Áreas seguras

Trabalhando em áreas seguras: Diretrizes para implementação

Convém que sejam levadas em consideração as seguintes diretrizes:

- a) o pessoal só tenha conhecimento da existência de áreas seguras ou das atividades nelas realizadas, se for necessário;
- b) seja evitado o trabalho não supervisionado em áreas seguras, tanto por motivos de segurança como para prevenir as atividades mal intencionadas;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Áreas seguras

Trabalhando em áreas seguras: Diretrizes para implementação

Convém que sejam levadas em consideração as seguintes diretrizes: c) as áreas seguras, não ocupadas, sejam fisicamente trancadas e periodicamente verificadas; d) não seja permitido o uso de máquinas fotográficas, gravadores de vídeo ou áudio ou de outros equipamentos de gravação, como câmeras em dispositivos móveis, salvo se for autorizado.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Áreas seguras

Trabalhando em áreas seguras: Informações adicionais

As normas para o trabalho em áreas seguras incluem o controle dos funcionários, fornecedores e partes externas que trabalham em tais áreas e cubram todas as atividades nestas áreas.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Áreas seguras

Áreas de entrega e de carregamento: Controle

Convém que pontos de acesso, como áreas de entrega e de carregamento e outros pontos em que pessoas não autorizadas possam entrar nas instalações, sejam controlados e, se possível, isolados das instalações de processamento da informação, para evitar o acesso não autorizado.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Áreas seguras

Áreas de entrega e de carregamento: Diretrizes para implementação

Convém que sejam levadas em consideração as seguintes diretrizes: a) convém que o acesso a uma área de entrega e carregamento a partir do exterior do prédio fique restrito ao pessoal identificado e autorizado; b) convém que as áreas de entrega e carregamento sejam projetadas de tal maneira que seja possível carregar e descarregar suprimentos sem que os entregadores tenham acesso a outras partes do edifício; c) convém que as portas externas de uma área de entrega e carregamento sejam protegidas enquanto as portas internas estiverem abertas;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Áreas seguras

Áreas de entrega e de carregamento: Diretrizes para implementação

Convém que sejam levadas em consideração as seguintes diretrizes: d) convém que os materiais entregues sejam inspecionados e examinados para detectar a presença de explosivos, materiais químicos ou outros materiais perigosos, antes de serem transportados da área de entrega e carregamento para o local de utilização; e) convém que os materiais entregues sejam registrados de acordo com os procedimentos de gerenciamento de ativos, por ocasião da sua entrada no local (ver Seção 8); f) convém que as remessas entregues sejam segregadas fisicamente das remessas que saem, sempre que possível; g) convém que os materiais entregues sejam inspecionados para evidenciar alteração indevida. Caso alguma alteração indevida seja descoberta, ela deve ser imediatamente notificada ao pessoal da segurança.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Cap. 11 - Segurança física e do ambiente

11.2 Equipamento

11.2.1 Localização e proteção do equipamento

11.2.2 Utilidades

11.2.3 Segurança do cabeamento

11.2.4 Manutenção dos equipamentos

11.2.5 Remoção de ativos

11.2.6 Segurança de equipamentos e ativos fora das dependências da organização

11.2.7 Reutilização ou descarte seguro de equipamentos

11.2.8 Equipamento de usuário sem monitoração

11.2.9 Política de mesa limpa e tela limpa

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Equipamento

Objetivo: Impedir perdas, danos, furto, ou comprometimento de ativos e interrupção das operações da organização.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Equipamento

Localização e proteção do equipamento: Controle

Convém que os equipamentos sejam protegidos e colocados em locais para reduzir os riscos de ameaças e perigos do meio ambiente, bem como as oportunidades de acesso não autorizado.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Equipamento

Localização e proteção do equipamento: Diretrizes para implementação

Convém que sejam levadas em consideração as seguintes diretrizes para proteger os equipamentos: a) convém que os equipamentos sejam colocados no local, a fim de minimizar o acesso desnecessário às áreas de trabalho; b) convém que as instalações de processamento da informação que manuseiam dados sensíveis sejam posicionadas cuidadosamente para reduzir o risco de que as informações sejam vistas por pessoal não autorizado durante a sua utilização; c) convém que as instalações de armazenamento sejam protegidas de forma segura para evitar acesso não autorizado; d) convém que os itens que exigem proteção especial sejam protegidos para reduzir o nível geral de proteção necessário;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Equipamento

Localização e proteção do equipamento: Diretrizes para implementação

Convém que sejam levadas em consideração as seguintes diretrizes para proteger os equipamentos; e) convém que sejam adotados controles para minimizar o risco de ameaças físicas potenciais e ambientais, como furto, incêndio, explosivos, fumaça, água (ou falha do suprimento de água), poeira, vibração, efeitos químicos, interferência com o suprimento de energia elétrica, interferência com as comunicações, radiação eletromagnética e vandalismo; f) convém que sejam estabelecidas diretrizes quanto a comer, beber e fumar nas proximidades das instalações de processamento da informação;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Equipamento

Localização e proteção do equipamento: Diretrizes para implementação

g) convém que as condições ambientais, como temperatura e umidade, sejam monitoradas para a detecção de condições que possam afetar negativamente as instalações de processamento da informação; h) convém que todos os edifícios sejam dotados de proteção contra raios e todas as linhas de entrada de força e de comunicações tenham filtros de proteção contra raios; i) para equipamentos em ambientes industriais, é recomendado considerar o uso de métodos especiais de proteção, como membranas para teclados; j) convém que os equipamentos que processam informações sensíveis sejam protegidos, a fim de minimizar o risco de vazamento de informações em decorrência de emissões eletromagnéticas.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Equipamento

Utilidades: Controle

Convém que os equipamentos sejam protegidos contra falta de energia elétrica e outras interrupções causadas por falhas das utilidades.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Equipamento

Utilidades: Diretrizes para implementação

Convém que todas as utilidades (como suprimento de energia elétrica, telecomunicações, suprimento de água, gás, esgoto, calefação/ventilação e ar-condicionado): a) estejam em conformidade com as especificações do fabricante do equipamento e com os requisitos legais da localidade;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Equipamento

Utilidades: Diretrizes para implementação

b) sejam avaliadas regularmente quanto à sua capacidade de atender ao crescimento do negócio e às interações com outras utilidades; c) sejam inspecionadas e testadas regularmente para assegurar o seu adequado funcionamento; d) sejam alarmadas para detectar mau funcionamento, quando necessário; e) tenham múltiplas alimentações com rotas físicas diferentes. Convém que seja providenciada iluminação e comunicação de emergência. Convém que as chaves de emergência (switches) e válvulas para o corte de energia, água, gás ou outras utilidades sejam localizadas próximas das saídas de emergência ou salas de equipamentos.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Equipamento

Utilidades: Informações adicionais

Redundância adicional para conectividade em rede pode ser obtida por meio de múltiplas rotas de mais de um provedor de utilidades.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Equipamento

Segurança do cabeamento: Controle

Convém que o cabeamento de energia e de telecomunicações que transporta dado ou dá suporte aos serviços de informações seja protegido contra interceptação, interferência ou danos.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Equipamento

Segurança do cabeamento: Diretrizes para implementação

Convém que sejam levadas em consideração as seguintes diretrizes para a segurança do cabeamento:

- a) convém que as linhas de energia e de telecomunicações que entram nas instalações de processamento da informação sejam subterrâneas (ou fiquem abaixo do piso) sempre que possível, ou recebam uma proteção alternativa adequada;
- b) convém que os cabos de energia sejam segregados dos cabos de comunicações, para evitar interferências;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Equipamento

Segurança do cabeamento: Informações adicionais

Para sistemas sensíveis ou críticos, convém que os seguintes controles adicionais, sejam considerados:

- 1) instalação de conduítes blindados e salas ou caixas trancadas em pontos de inspeção e pontos terminais;
- 2) utilização de blindagem eletromagnética para a proteção dos cabos;
- 3) realização de varreduras técnicas e inspeções físicas para detectar a presença de dispositivos não autorizados conectados aos cabos;
- 4) acesso controlado aos painéis de conexões e às salas de cabos.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Equipamento

Manutenção dos equipamentos: Controle

Convém que os equipamentos tenham uma manutenção correta para assegurar a sua contínua integridade e disponibilidade.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Equipamento

Manutenção dos equipamentos: Controle

Convém que os equipamentos tenham uma manutenção correta para assegurar a sua contínua integridade e disponibilidade.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Equipamento

Manutenção dos equipamentos: Diretrizes para implementação

Convém que sejam levadas em consideração as seguintes diretrizes para a manutenção dos equipamentos:

- a) convém que a manutenção dos equipamentos seja realizada nos intervalos recomendados pelo fornecedor e de acordo com as suas especificações;
- b) convém que a manutenção e os consertos dos equipamentos só sejam realizados por pessoal de manutenção autorizado;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Equipamento

Manutenção dos equipamentos: Diretrizes para implementação

- c) convém que sejam mantidos registros de todas as falhas, suspeitas ou reais, e de todas as operações de manutenção preventiva e corretiva realizadas;
- d) convém que sejam implementados controles apropriados, na época programada para a manutenção do equipamento, dependendo de a manutenção ser realizada pelo pessoal local ou por pessoal externo à organização; onde necessário, convém que informações sensíveis sejam eliminadas do equipamento, ou o pessoal de manutenção seja de absoluta confiança;
- e) convém que sejam atendidas todas as exigências de manutenção estabelecidas nas apólices de seguro;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Equipamento

Manutenção dos equipamentos: Informações adicionais

Antes de colocar o equipamento em operação, após a sua manutenção, convém que ele seja inspecionado para garantir que não foi alterado indevidamente e que não está em mau funcionamento.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Equipamento

Remoção de ativos: Controle

Convém que equipamentos, informações ou software não sejam retirados do local sem autorização prévia.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Equipamento

Remoção de ativos: Diretrizes para implementação

Convém que sejam levadas em consideração as seguintes diretrizes:

- a) convém que sejam claramente identificados os funcionários, fornecedores e partes externas que tenham autoridade para permitir a remoção de ativos para fora do local;
- b) convém que sejam estabelecidos limites de tempo para a retirada de equipamentos do local, e que a devolução seja controlada;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Equipamento

Remoção de ativos: Diretrizes para implementação

Convém que sejam levadas em consideração as seguintes diretrizes:

- c) sempre que necessário ou apropriado, é recomendado que seja feito um registro da retirada e da devolução de ativos, quando do seu retorno;
- d) convém que a identidade, atribuição e função de qualquer pessoa que manuseia ou utiliza os ativos estejam documentadas, e que esta documentação seja devolvida com o equipamento, a informação ou o software.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Equipamento

Remoção de ativos: Informações adicionais

Podem ser feitas inspeções aleatórias para detectar a retirada não autorizada de ativos e a existência de equipamentos de gravação não autorizados, armas etc., e para impedir sua entrada e saída do local.

Convém que tais inspeções aleatórias sejam feitas de acordo com a legislação e as normas aplicáveis.

Convém que as pessoas sejam avisadas da realização das inspeções, e que elas só possam ser feitas com a devida autorização, levando em conta as exigências legais e regulamentares.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Equipamento

Segurança de equipamentos e ativos fora das dependências da organização: Controle

Convém que sejam tomadas medidas de segurança para ativos que operem fora do local, levando em conta os diferentes riscos decorrentes do fato de se trabalhar fora das dependências da organização.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Equipamento

Segurança de equipamentos e ativos fora das dependências da organização: Diretrizes para implementação

Convém que o uso de qualquer equipamento de processamento e armazenamento de informações fora das dependências da organização seja autorizado pela gerência. Isto se aplica aos próprios equipamentos da organização e aos equipamentos pessoais, usados em nome da organização.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Equipamento

Segurança de equipamentos e ativos fora das dependências da organização: Diretrizes para implementação

Convém que as seguintes diretrizes sejam adotadas para a proteção de equipamentos usados fora das dependências da organização:

- a) convém que os equipamentos e mídias removidos das dependências da organização não fiquem sem supervisão em lugares públicos;
- b) convém que sejam observadas a qualquer tempo as instruções do fabricante para a proteção do equipamento, por exemplo, proteção contra a exposição a campos eletromagnéticos intensos;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Equipamento

Segurança de equipamentos e ativos fora das dependências da organização: Diretrizes para implementação

- c) convém que os controles para as localidades fora das dependências da organização, como, o trabalho em casa e localidades remotas e temporárias, sejam determinados por uma avaliação de riscos, devendo ser aplicados controles adequados para cada caso, por exemplo, arquivos trancáveis, política de “mesa limpa”, controles de acesso a computadores, e comunicação segura com o escritório.
- d) quando o equipamento fora das dependências da organização é transferido entre diferentes pessoas ou partes externas, convém que seja mantido um registro para definir a cadeia de custódia do equipamento, incluindo pelo menos os nomes e organizações daqueles que são responsáveis pelo equipamento.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Equipamento

Segurança de equipamentos e ativos fora das dependências da organização: Diretrizes para implementação

Os riscos de segurança, por exemplo, de danos, furto ou espionagem, podem variar consideravelmente de um local para outro, e convém que sejam levados em conta para determinar os controles mais apropriados.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Equipamento

Segurança de equipamentos e ativos fora das dependências da organização: Informações adicionais

Os equipamentos de armazenamento e processamento de informações incluem todas as formas de computadores pessoais, agendas eletrônicas, telefones celulares, cartões inteligentes, papéis e outros tipos, utilizados no trabalho em casa, ou que são removidos do local normal de trabalho.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Equipamento

Reutilização ou descarte seguro de equipamentos: Controle

Convém que todos os equipamentos que contenham mídias de armazenamento de dados sejam examinados antes da reutilização, para assegurar que todos os dados sensíveis e software licenciados tenham sido removidos ou sobre gravados com segurança.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Equipamento

Reutilização ou descarte seguro de equipamentos: Diretrizes para implementação

Convém que os equipamentos sejam inspecionados para verificar se a mídia está ou não armazenada, antes do descarte ou reutilização.

Convém que as mídias de armazenamento que contêm informações confidenciais ou de direitos autorais sejam destruídas fisicamente, ou as informações sejam destruídas, apagadas ou sobre gravadas por meio de técnicas que tornem as informações originais irrecuperáveis, em vez de se usarem as funções-padrão de apagar ou formatar.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Equipamento

Reutilização ou descarte seguro de equipamentos: Informações adicionais

No caso de dispositivos defeituosos que contenham informações sensíveis, pode ser necessária uma avaliação de riscos para determinar se convém destruir fisicamente o dispositivo em vez de mandá-lo para o conserto ou descartá-lo.

As informações podem ser comprometidas por um descarte feito sem os devidos cuidados ou pela reutilização do equipamento.

Adicionalmente à remoção segura das informações contidas no disco, a encriptação completa do disco reduz o risco de revelação de informação confidencial quando o equipamento é descartado ou reparado, considerando que:

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Equipamento

Reutilização ou descarte seguro de equipamentos: Informações adicionais

- a) o processo de encriptação é suficientemente robusto e cobre o disco por completo (incluindo slack space, swap files etc.);
- b) as chaves criptográficas são de um tamanho considerável para resistir a um ataque de força bruta;
- c) as chaves criptográficas são guardadas de forma confidencial (por exemplo, nunca armazenadas no mesmo disco). Para orientações adicionais sobre criptografia.
- d) Técnicas para sobre gravar de forma segura as mídias armazenadas diferem em função da tecnologia usada para armazenar a mídia. Convém que ferramentas usadas para sobre gravar sejam analisadas criticamente para assegurar que elas sejam aplicáveis à tecnologia usada para o armazenamento da mídia.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Equipamento

Equipamento de usuário sem monitoração: Controle

Convém que os usuários assegurem que os equipamentos não monitorados tenham proteção adequada.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Equipamento

Equipamento de usuário sem monitoração: Diretrizes para implementação

Convém que todos os usuários estejam cientes dos requisitos de segurança da informação e procedimentos para proteger equipamentos desacompanhados, assim como suas responsabilidades por implementar estas proteções. Convém que os usuários sejam informados para: a) encerrar as sessões ativas, a menos que elas possam ser protegidas por meio de um mecanismo de bloqueio, por exemplo tela de proteção com senha; b) efetuar a desconexão de serviços de rede ou aplicações, quando não for mais necessário; c) proteger os computadores ou dispositivos móveis contra uso não autorizado através de tecla de bloqueio ou outro controle equivalente, por exemplo, senha de acesso, quando não estiver em uso.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Equipamento

Equipamento de usuário sem monitoração: Informações adicionais

Proteger os computadores ou dispositivos móveis contra uso não autorizado através de tecla de bloqueio ou outro controle equivalente, por exemplo, senha de acesso, quando não estiver em uso.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Equipamento

Política de mesa limpa e tela limpa: Controle

Convém que sejam adotadas uma política de mesa limpa para papéis e mídias de armazenamento removíveis e uma política de tela limpa para os recursos de processamento da informação.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Equipamento

Política de mesa limpa e tela limpa: Diretrizes para implementação

Convém que uma política de mesa limpa e tela protegida leve em consideração a classificação da informação, requisitos contratuais e legais, e o risco correspondente e aspectos culturais da organização.

Convém que as seguintes diretrizes sejam consideradas: a) convém que as informações do negócio sensíveis ou críticas, por exemplo, em papel ou em mídia de armazenamento eletrônicas, sejam guardadas em lugar seguro (idealmente em um cofre, armário ou outras formas de mobília de segurança), quando não em uso, especialmente quando o escritório estiver desocupado;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Equipamento

Política de mesa limpa e tela limpa: Diretrizes para implementação

b) convém que os computadores e terminais sejam mantidos desligados ou protegidos com mecanismo de travamento de tela e teclados controlados por senha, token ou mecanismo de autenticação similar, quando sem monitoração, e protegidos por tecla de bloqueio, senhas ou outros controles, quando não usados; c) convém que seja evitado o uso não autorizado de fotocopiadoras e de outra tecnologia de reprodução (por exemplo, scanners, máquinas fotográficas digitais); d) convém que os documentos que contêm informação sensível ou classificada sejam removidos de impressoras imediatamente.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança física e do ambiente

Equipamento

Política de mesa limpa e tela limpa: Informações adicionais

Uma política de mesa limpa e tela protegida reduz o risco de acesso não autorizado, perda e dano da informação durante e fora do horário normal de trabalho. Cofres e outras formas de recursos de armazenamento seguro também podem proteger informações armazenadas contra desastres como incêndio, terremoto, enchente ou explosão. Considerar o uso de impressoras com função de código PIN, permitindo dessa forma que os requerentes sejam os únicos que podem pegar suas impressões, e apenas quando estiverem próximos às impressoras.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002:

Cap. 12 - Segurança nas operações

12.1 Responsabilidades e procedimentos operacionais

12.1.1 Documentação dos procedimentos de operação

12.1.2 Gestão de mudanças

12.1.3 Gestão de capacidade

12.1.4 Separação dos ambientes de desenvolvimento, teste e produção

12.2 Proteção contra malware

12.2.1 Controles contra malware

12.3 Cópias de segurança

12.3.1 Cópias de segurança das informações

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002:

Cap. 12 - Segurança nas operações

12.4 Registros e monitoramento

12.4.1 Registros de eventos

12.4.2 Proteção das informações dos registros de eventos (logs)

12.4.3 Registros de eventos (log) de administrador e operador

12.4.4 Sincronização dos relógios

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança nas operações

12.1 Responsabilidades e procedimentos operacionais: Objetivo

Garantir a operação segura e correta dos recursos de processamento da informação.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança nas operações

12.1 Responsabilidades e procedimentos operacionais

12.1.1 Documentação dos procedimentos de operação: Controle

Convém que os procedimentos de operação sejam documentados e disponibilizados para todos os usuários que necessitem deles.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança nas operações

12.1 Responsabilidades e procedimentos operacionais

12.1.1 Documentação dos procedimentos de operação: Diretrizes para implementação

Convém que os procedimentos documentados sejam preparados para as atividades operacionais associadas a recursos de processamento de comunicação e informações, como procedimentos de inicialização e desligamento de computadores, geração de cópias de segurança (backup), manutenção de equipamentos, tratamento de mídias, segurança e gestão do tratamento das correspondências e das salas de computadores.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança nas operações

12.1 Responsabilidades e procedimentos operacionais

12.1.1 Documentação dos procedimentos de operação: Diretrizes para implementação

Convém que os procedimentos de operação especifiquem as instruções, incluindo:

- a) a instalação e configuração de sistemas;
- b) processamento e tratamento da informação, tanto automática como manual;
- c) cópias de segurança (backup);
- d) requisitos de agendamento, incluindo interdependências com outros sistemas, a primeira hora para início da tarefa e a última hora para o término da tarefa;
- e) instruções para tratamento de erros ou outras condições excepcionais, que possam ocorrer durante a execução de uma tarefa, incluindo restrições de uso dos utilitários do sistema;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança nas operações

12.1 Responsabilidades e procedimentos operacionais

12.1.1 Documentação dos procedimentos de operação: Diretrizes para implementação

- f) contatos para suporte e escalção, incluindo contatos de suporte externos, para o caso de eventos operacionais inesperados ou dificuldades técnicas;
- g) instruções quanto ao manuseio de mídias e saídas especiais, como o uso de formulários especiais ou o gerenciamento de dados confidenciais, incluindo procedimentos para o descarte seguro de resultados provenientes de rotinas com falhas;
- h) procedimento para o reinício e recuperação em caso de falha do sistema;
- i) gerenciamento de trilhas de auditoria e informações de registros (logs) de sistemas;
- j) procedimentos de monitoramento.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança nas operações

12.1 Responsabilidades e procedimentos operacionais

12.1.1 Documentação dos procedimentos de operação: Informações adicionais

Convém que os procedimentos operacionais e os procedimentos documentados para atividades de sistemas sejam tratados como documentos formais e as mudanças sejam autorizadas pela direção. Quando tecnicamente possível, convém que sistemas de informação sejam gerenciados uniformemente, usando os mesmos procedimentos, ferramentas e utilitários.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança nas operações

12.1 Responsabilidades e procedimentos operacionais

12.1.2 Gestão de mudanças: Controle

Convém que mudanças na organização, nos processos do negócio, nos recursos de processamento da informação e nos sistemas que afetam a segurança da informação, sejam controladas.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança nas operações

12.1 Responsabilidades e procedimentos operacionais

12.1.2 Gestão de mudanças: Diretrizes para implementação

Convém que os seguintes itens, em particular, sejam considerados:

- a) identificação e registro das mudanças significativas;
- b) planejamento e testes das mudanças;
- c) avaliação de impactos potenciais, incluindo impactos de segurança da informação de tais mudanças;
- d) procedimento formal de aprovação das mudanças propostas;
- e) verificação de que os requisitos de segurança da informação foram atendidos;
- f) comunicação dos detalhes das mudanças para todas as pessoas relevantes;
- g) procedimentos de recuperação, incluindo procedimentos e responsabilidades para interrupção e recuperação de mudanças em caso de insucesso ou na ocorrência de eventos inesperados;
- h) provisão de um processo emergencial de mudança para permitir uma implementação rápida e controlada de mudanças, necessárias para resolver um incidente.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança nas operações

12.1 Responsabilidades e procedimentos operacionais

12.1.2 Gestão de mudanças: Diretrizes para implementação

Convém que sejam estabelecidos procedimentos e responsabilidades de gestão formais para garantir que haja um controle satisfatório de todas as mudanças. Quando mudanças forem realizadas, é conveniente manter um registro de auditoria contendo todas as informações relevantes.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança nas operações

12.1 Responsabilidades e procedimentos operacionais

12.1.2 Gestão de mudanças: Informações adicionais

O controle inadequado de modificações nos sistemas e nos recursos de processamento das informações é uma causa comum de falhas de segurança ou de sistema. Mudanças em ambientes operacionais, especialmente quando da transferência de um sistema em desenvolvimento para o estágio operacional, podem trazer impactos à confiabilidade de aplicações.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança nas operações

12.1 Responsabilidades e procedimentos operacionais

12.1.3 Gestão de capacidade: Controle

Convém que a utilização dos recursos seja monitorada e ajustada, e que as projeções sejam feitas para necessidades de capacidade futura para garantir o desempenho requerido do sistema.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança nas operações

12.1 Responsabilidades e procedimentos operacionais

12.1.3 Gestão de capacidade: Diretrizes para implementação

Convém que requisitos de capacidade sejam identificados levando-se em conta a criticidade do negócio do sistema em questão.

Convém que o ajuste e o monitoramento dos sistemas sejam aplicados para garantir e, quando necessário, melhorar a disponibilidade e eficiência dos sistemas. É recomendável que os controles detectivos sejam implantados para identificar problemas em tempo hábil. É conveniente que projeções de capacidade futura levem em consideração os requisitos de novos negócios e sistemas e as tendências atuais e projetadas de capacidade de processamento de informação da organização.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança nas operações

12.1 Responsabilidades e procedimentos operacionais

12.1.3 Gestão de capacidade: Diretrizes para implementação

Atenção particular precisa ser dada a qualquer recurso que possua um ciclo de renovação longo ou custo alto, sendo responsabilidade dos gestores monitorar a utilização dos recursos-chave dos sistemas.

Convém que eles identifiquem as tendências de utilização, particularmente em relação às aplicações do negócio ou às ferramentas de gestão de sistemas de informação.

Convém que os gestores utilizem essas informações para identificar e evitar os potenciais gargalos e a dependência em pessoas chave que possam representar ameaças à segurança dos sistemas ou aos serviços, e planejar ação apropriada.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança nas operações

12.1 Responsabilidades e procedimentos operacionais

12.1.3 Gestão de capacidade: Diretrizes para implementação

O fornecimento de capacidade suficiente pode ser obtido por meio do aumento de capacidade ou pela redução da demanda. Exemplos de gerenciamento da demanda de capacidade incluem:

- a) exclusão de dados obsoletos (espaço em disco); b) desativação de aplicações, sistemas, bases de dados ou ambientes; c) otimização das programações e dos processos de lote; d) otimização da lógica de aplicação ou das consultas à base de dados; e) negar ou restringir a largura da banda para serviços que demandam muitos recursos, se estes não forem críticos ao negócio (por exemplo, streaming de vídeo).

Convém que um plano documentado da gestão de capacidade seja considerado para os sistemas de missão crítica.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança nas operações

12.1 Responsabilidades e procedimentos operacionais

12.1.3 Gestão de capacidade: Informações adicionais

Este controle também considera a capacidade dos recursos humanos, bem como dos escritórios e instalações.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança nas operações

12.1 Responsabilidades e procedimentos operacionais

12.1.4 Separação dos ambientes de desenvolvimento, teste e produção: Controle

Convém que ambientes de desenvolvimento, teste e produção sejam separados para reduzir os riscos de acessos ou modificações não autorizadas no ambiente de produção.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança nas operações

12.1 Responsabilidades e procedimentos operacionais

12.1.4 Separação dos ambientes de desenvolvimento, teste e produção: Diretrizes para implementação

Convém que o nível de separação dos ambientes de produção, testes e desenvolvimento, que é necessário para prevenir problemas operacionais, seja identificado e os controles apropriados sejam implementados.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança nas operações

12.1 Responsabilidades e procedimentos operacionais

12.1.4 Separação dos ambientes de desenvolvimento, teste e produção: Diretrizes para implementação

Convém que os seguintes itens sejam considerados: a) convém que as regras para a transferência de software do ambiente de desenvolvimento para o de produção sejam definidas e documentadas; b) convém que o software em desenvolvimento e o software em produção sejam, sempre que possível, executados em diferentes sistemas ou processadores e em diferentes domínios ou diretórios; c) convém que as mudanças nas aplicações e nos sistemas operacionais sejam testadas em um ambiente de teste ou projeto-piloto, antes de serem aplicadas aos sistemas operacionais; d) convém que os testes não sejam realizados nos sistemas operacionais, exceto em circunstâncias excepcionais;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança nas operações

12.1 Responsabilidades e procedimentos operacionais

12.1.4 Separação dos ambientes de desenvolvimento, teste e produção: Informações adicionais

As atividades de desenvolvimento e teste podem causar sérios problemas, como, por exemplo, modificações inesperadas em arquivos ou no ambiente dos sistemas, ou falhas de sistemas. Nesse caso, é necessária a manutenção de um ambiente conhecido e estável, no qual possam ser executados testes significativos e que seja capaz de prevenir o acesso indevido do pessoal de desenvolvimento ao ambiente operacional.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança nas operações

12.2 Proteção contra malware

Objetivo: Assegurar que as informações e os recursos de processamento da informação estão protegidos contra malware.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança nas operações

12.2 Proteção contra malware

12.2.1 Controles contra malware: Controle

Convém que sejam implementados controles de detecção, prevenção e recuperação para proteger contra malware, combinados com um adequado programa de conscientização do usuário.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança nas operações

12.2 Proteção contra malware

12.2.1 Controles contra malware: Diretrizes para implementação

Convém que a proteção contra malware seja baseada em software de detecção e resposta a malware, na conscientização da segurança da informação, no controle de acesso adequado e nos controles de gerenciamento de mudanças. Recomenda-se que os seguintes controles sejam considerados: a) estabelecer uma política formal proibindo o uso de software não autorizados; b) implementar controles para prevenir ou detectar o uso de software não autorizado (por exemplo, whitelisting, ou seja, uma lista de software permitidos a acessar o sistema);

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança nas operações

12.2 Proteção contra malware

12.2.1 Controles contra malware: Diretrizes para implementação

c) implementar controles para prevenir ou detectar o uso de websites maliciosos, suspeitos ou conhecidos (por exemplo blacklisting, ou seja, uma lista de software permitidos a acessar o sistema); d) estabelecer uma política formal para proteção contra os riscos associados com a importação de arquivos e software, seja de redes externas, ou por qualquer outro meio, indicando as medidas preventivas a serem adotadas; e) reduzir vulnerabilidades que possam ser exploradas por malware, por exemplo, por meio do gerenciamento de vulnerabilidades técnicas; f) conduzir análises críticas regulares dos software e dados dos sistemas que suportam processos críticos de negócio; convém que a presença de quaisquer arquivos não aprovados ou atualização não autorizada seja formalmente investigada;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança nas operações

12.2 Proteção contra malware

12.2.1 Controles contra malware: Diretrizes para implementação

g) instalar e atualizar regularmente software de detecção e remoção de malware para o exame de computadores e mídias magnéticas, de forma preventiva ou de forma rotineira; convém que as verificações realizadas incluam: 1) varredura, antes do uso, da existência de malware nos arquivos recebidos por meio de redes ou em qualquer mídia de armazenamento; 2) verificação, antes do uso, da existência de software malicioso em qualquer arquivo recebido através de correio eletrônico ou importado (download). Essa avaliação pode ser feita em diversos locais, como, por exemplo, nos servidores de correio eletrônico, nos computadores pessoais ou quando da sua entrada na rede da organização; 3) verificação da existência de malware em páginas web;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança nas operações

12.2 Proteção contra malware

12.2.1 Controles contra malware: Diretrizes para implementação

h) definir procedimentos e responsabilidades para tratar da proteção de malware nos sistemas, treinamento nesses procedimentos, reporte e recuperação de ataques de malware; i) preparar planos de continuidade do negócio adequados para a recuperação em caso de ataques por malware, incluindo todos os procedimentos necessários para recuperação e cópia dos dados e software; j) implementar procedimentos para coletar regularmente informações, através, por exemplo, de assinaturas de listas de discussão e visitas a sites informativos sobre novos malware; k) implementar procedimentos para verificar a informação relacionada a malware e garantir que os boletins com alertas sejam precisos e informativos; convém que os gestores garantam que fontes qualificadas, como, por exemplo, jornais com reputação idônea, sites confiáveis ou fornecedores de software de proteção contra malware, sejam utilizadas para diferenciar boatos de notícias reais sobre malware; convém que todos os usuários estejam cientes dos problemas decorrentes de boatos e estejam capacitados a lidar com eles; l) isolar os ambientes onde impactos catastróficos possam ser gerados.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança nas operações

12.2 Proteção contra malware

12.2.1 Controles contra malware: Informações adicionais

A utilização de dois ou mais tipos de software de controle contra malware de diferentes fornecedores e tecnologias no ambiente de processamento da informação pode aumentar a eficácia na proteção contra malware.

Convém que seja tomado cuidado para proteção contra a introdução de malware durante manutenções e procedimentos de emergência, os quais podem ultrapassar os controles comuns de proteção contra malware. Sob certas condições, a proteção contra malware pode causar perturbação nas operações. O uso isolado de software de reparação e detecção contra malware não é usualmente adequado e geralmente necessita ser acompanhado de procedimentos operacionais que previnam a introdução de malware.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança nas operações

12.3 Cópias de segurança

Objetivo: Proteger contra a perda de dados.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança nas operações

12.3 Cópias de segurança

12.3.1 Cópias de segurança das informações: Controle

Convém que cópias de segurança das informações, dos software e das imagens do sistema sejam efetuadas e testadas regularmente conforme a política de geração de cópias de segurança definida.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança nas operações

12.3 Cópias de segurança

12.3.1 Cópias de segurança das informações: Diretrizes para implementação

Convém que a política de backup seja estabelecida para definir os requisitos da organização relativos às cópias de segurança das informações, dos software e dos sistemas.

Convém que a política de backup defina os requisitos para proteção e retenção.

Convém que os recursos adequados para a geração de cópias de segurança sejam disponibilizados para garantir que toda informação e os software essenciais possam ser recuperados após um desastre ou a falha de uma mídia.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança nas operações

12.3 Cópias de segurança

12.3.1 Cópias de segurança das informações: Diretrizes para implementação

Convém que procedimentos operacionais monitorem a execução dos backup e apontem falhas de backup programado, para garantir a integralidade dos backup, de acordo com a política de backup.

Convém que cópias de segurança de sistemas e serviços específicos sejam testadas regularmente para garantir que elas estão aderentes aos requisitos definidos nos planos de continuidade do negócio. Para serviços e sistemas críticos, convém que sejam criados mecanismos de geração de cópias de segurança que abranjam todos os sistemas de informação, aplicações e dados necessários para a completa recuperação do sistema em um evento de desastre.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança nas operações

12.3 Cópias de segurança

12.3.1 Cópias de segurança das informações: Informações adicionais

Convém que sejam determinados o período de retenção para informações essenciais ao negócio e também qualquer requisito para que cópias de arquivo sejam permanentemente retidas.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança nas operações

12.4 Registros e monitoramento

Objetivo: Registrar eventos e gerar evidências.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança nas operações

12.4 Registros e monitoramento

12.4.1 Registros de eventos: Controle

Convém que registros (log) de eventos das atividades do usuário, exceções, falhas e eventos de segurança da informação sejam produzidos, mantidos e analisados criticamente, a intervalos regulares.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança nas operações

12.4 Registros e monitoramento

12.4.1 Registros de eventos: Diretrizes para implementação

Convém que os registros (log) de eventos incluam, quando relevante:

a) identificação dos usuários (ID); b) atividades do sistema; c) datas, horários e detalhes de eventos-chave, como, por exemplo, horário de entrada (log-on) e saída (log-off) no sistema; d) identidade do dispositivo ou sua localização, quando possível, e o identificador do sistema; e) registros das tentativas de acesso ao sistema, aceitas e rejeitadas; f) registros das tentativas de acesso a outros recursos e dados, aceitas e rejeitadas; g) alterações na configuração do sistema; h) uso de privilégios;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: Segurança nas operações

12.4 Registros e monitoramento

12.4.1 Registros de eventos: Informações adicionais

Os registros (log) de eventos podem conter dados confidenciais e informação de identificação pessoal.

Convém que medidas apropriadas de proteção de privacidade sejam tomadas (ver 18.1.4).

Quando possível, convém que os administradores de sistemas não tenham permissão de exclusão ou desativação dos registros (log) de suas próprias atividades (ver 12.4.3).

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 13 - Segurança nas comunicações

Cap. 13 – Segurança nas comunicações

13.1 Gerenciamento da segurança em redes

13.1.1 Controles de redes

13.1.2 Segurança dos serviços de rede

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 13 - Segurança nas comunicações

13.1 Gerenciamento da segurança em redes

Objetivo: Assegurar a proteção das informações em redes e dos recursos de processamento da informação que as apoiam.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 13 - Segurança nas comunicações

13.1 Gerenciamento da segurança em redes

13.1.1 Controles de redes: Controle

Convém que as redes sejam gerenciadas e controladas para proteger as informações nos sistemas e aplicações.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 13 - Segurança nas comunicações

13.1 Gerenciamento da segurança em redes

13.1.1 Controles de redes: Diretrizes para implementação

Convém que controles sejam implementados para garantir a segurança da informação nestas redes, e a proteção dos serviços a elas conectadas, contra acesso não autorizado. Em particular, convém que os seguintes itens sejam considerados:

- a) convém que responsabilidades e procedimentos sobre o gerenciamento de equipamentos de rede sejam estabelecidos;
- b) convém que a responsabilidade operacional pelas redes seja separada da operação dos recursos computacionais, onde apropriado;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 13 - Segurança nas comunicações

13.1 Gerenciamento da segurança em redes

13.1.1 Controles de redes: Informações adicionais

Informações adicionais sobre segurança em rede pode ser encontrada na ISO/IEC 27033

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 13 - Segurança nas comunicações

13.1 Gerenciamento da segurança em redes

13.1.2 Segurança dos serviços de rede: Controle

Convém que mecanismos de segurança, níveis de serviço e requisitos de gerenciamento de todos os serviços de rede sejam identificados e incluídos em qualquer acordo de serviços de rede, tanto para serviços de rede providos internamente como para terceirizados.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 13 - Segurança nas comunicações

13.1 Gerenciamento da segurança em redes

13.1.2 Segurança dos serviços de rede: Diretrizes para implementação

Convém que a capacidade do provedor dos serviços de rede para gerenciar os serviços acordados de maneira segura seja determinada e monitorados regularmente, bem como o direito de auditá-los seja acordado. É conveniente que as definições de segurança necessárias para serviços específicos, como características de segurança, níveis de serviço e requisitos de gerenciamento, sejam identificadas. Convém que a organização assegure que os provedores dos serviços de rede implementam estas medidas.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 13 - Segurança nas comunicações

13.1 Gerenciamento da segurança em redes

13.1.2 Segurança dos serviços de rede: Informações adicionais

Serviços de rede incluem o fornecimento de conexões, serviços de rede privados, redes de valor agregado e soluções de segurança de rede gerenciadas como firewalls e sistemas de detecção de intrusos. Estes serviços podem abranger desde o simples fornecimento de banda de rede não gerenciada até complexas ofertas de soluções de valor agregado.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002:

14 Aquisição, desenvolvimento e manutenção de sistemas

14.1 Requisitos de segurança de sistemas de informação

14.1.1 Análise e especificação dos requisitos de segurança da informação

14.1.2 Serviços de aplicação seguros em redes públicas

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 14 Aquisição, desenvolvimento e manutenção de sistemas

14.1 Requisitos de segurança de sistemas de informação

Objetivo: Garantir que a segurança da informação seja parte integrante de todo o ciclo de vida dos sistemas de informação. Isto também inclui os requisitos para sistemas de informação que fornecem serviços sobre as redes públicas.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 14 Aquisição, desenvolvimento e manutenção de sistemas

14.1 Requisitos de segurança de sistemas de informação

14.1.1 Análise e especificação dos requisitos de segurança da informação: Controle

Convém que os requisitos relacionados à segurança da informação sejam incluídos nos requisitos para novos sistemas de informação ou melhorias dos sistemas de informação existentes.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 14 Aquisição, desenvolvimento e manutenção de sistemas

14.1 Requisitos de segurança de sistemas de informação

14.1.1 Análise e especificação dos requisitos de segurança da informação: Diretrizes para implementação

Convém que os requisitos de segurança da informação sejam identificados usando vários métodos, como requisitos de conformidade oriundos de política e regulamentações, modelos de ameaças, análises críticas de incidentes ou o uso de limiares de vulnerabilidade.

Convém que os resultados da identificação sejam documentados e analisados criticamente por todas as partes interessadas.

Convém que os controles e requisitos de segurança da informação reflitam o valor da informação envolvida para o negócio e o seu potencial impacto negativo, que possa resultar de uma falha da segurança da informação.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 14 Aquisição, desenvolvimento e manutenção de sistemas

14.1 Requisitos de segurança de sistemas de informação

14.1.1 Análise e especificação dos requisitos de segurança da informação: Informações adicionais

A ABNT NBR ISO/IEC 27005[11] e a ABNT NBR ISO 31000[27] fornecem diretrizes sobre o uso de processos de gestão de riscos, para identificar controles que atendam aos requisitos de segurança da informação.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 14 Aquisição, desenvolvimento e manutenção de sistemas

14.1 Requisitos de segurança de sistemas de informação

14.1.2 Serviços de aplicação seguros em redes públicas: Controle

Convém que as informações envolvidas nos serviços de aplicação que transitam sobre redes públicas sejam protegidas de atividades fraudulentas, disputas contratuais e divulgação e modificações não autorizadas.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 14 Aquisição, desenvolvimento e manutenção de sistemas

14.1 Requisitos de segurança de sistemas de informação

14.1.2 Serviços de aplicação seguros em redes públicas: Diretrizes para implementação

Convém que as considerações de segurança da informação para serviços de aplicação que transitam sobre redes públicas considerem os seguintes itens: a) o nível de confiança que cada parte requer na identidade alegada, como, por exemplo, através de autenticação; b) processos de autorização associados com quem pode aprovar conteúdos, publicar ou assinar documentos-chave transacionais; c) garantia de que os parceiros de comunicação estejam completamente informados de suas autorizações para o fornecimento ou uso do serviço;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 14 Aquisição, desenvolvimento e manutenção de sistemas

14.1 Requisitos de segurança de sistemas de informação

14.1.2 Serviços de aplicação seguros em redes públicas: Informações adicionais

Aplicações acessadas através de redes públicas são suscetíveis a uma variedade de ameaças de rede, como atividades fraudulentas, disputas contratuais ou divulgação de informação para o público. Por estes motivos, uma avaliação de riscos detalhada e uma seleção de controles apropriada são indispensáveis. Os controles requeridos sempre incluem métodos de criptografia para autenticação e segurança na transferência dos dados.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002:

15 Relacionamento na cadeia de suprimento

15.1 Segurança da informação na cadeia de suprimento

15.1.1 Política de segurança da informação no relacionamento com os fornecedores:

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 15 Relacionamento na cadeia de suprimento

15.1 Segurança da informação na cadeia de suprimento

Objetivo: Garantir a proteção dos ativos da organização que são acessados pelos fornecedores.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 15 Relacionamento na cadeia de suprimento

15.1 Segurança da informação na cadeia de suprimento

15.1.1 Política de segurança da informação no relacionamento com os fornecedores: Controle

Convém que os requisitos de segurança da informação para mitigar os riscos associados com o acesso dos fornecedores aos ativos da organização sejam acordados com o fornecedor e documentados.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 15 Relacionamento na cadeia de suprimento

15.1 Segurança da informação na cadeia de suprimento

15.1.1 Política de segurança da informação no relacionamento com os fornecedores: Diretrizes para implementação

Convém que a organização identifique e exija os controles de segurança da informação para tratar, especificamente, do acesso do fornecedor às informações da organização, através de uma política.

Convém que estes controles considerem os procedimentos e processos a serem implementados pela organização, bem como aqueles processos e procedimentos que a organização requeira do fornecedor a sua implementação, incluindo:

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 15 Relacionamento na cadeia de suprimento

15.1 Segurança da informação na cadeia de suprimento

15.1.1 Política de segurança da informação no relacionamento com os fornecedores: Diretrizes para implementação

- a) identificação e documentação dos tipos de fornecedores, por exemplo, serviços de TI, utilidades, serviços financeiros, componentes de infraestrutura de TI, aos quais a organização permitirá acessar suas informações;
- b) um processo padronizado e o ciclo de vida para gerenciar as relações com o fornecedor;
- c) definição dos tipos de acesso à informação que diferentes tipos de fornecedores terão permissão, o monitoramento e o controle do acesso;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 15 Relacionamento na cadeia de suprimento

15.1 Segurança da informação na cadeia de suprimento

15.1.1 Política de segurança da informação no relacionamento com os fornecedores: Informações adicionais

As informações podem ser colocadas em risco por fornecedores com a gestão da segurança da informação inadequada. Convém que controles sejam identificados e aplicados para administrar os acessos dos fornecedores aos recursos de processamento da informação.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002:

16 - Gestão de incidentes de segurança da informação

16.1 Gestão de incidentes de segurança da informação e melhorias

16.1.1 Responsabilidades e procedimentos

16.1.2 Notificação de eventos de segurança da informação

16.1.3 Notificando fragilidades de segurança da informação

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 16 - Gestão de incidentes de segurança da informação

16.1 Gestão de incidentes de segurança da informação e melhorias

Objetivo: Assegurar um enfoque consistente e efetivo para gerenciar os incidentes de segurança da informação, incluindo a comunicação sobre fragilidades e eventos de segurança da informação.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 16 - Gestão de incidentes de segurança da informação

16.1 Gestão de incidentes de segurança da informação e melhorias

16.1.1 Responsabilidades e procedimentos: Controle

Convém que responsabilidades e procedimentos de gestão sejam estabelecidos para assegurar respostas rápidas, efetivas e ordenadas aos incidentes de segurança da informação.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 16 - Gestão de incidentes de segurança da informação

16.1 Gestão de incidentes de segurança da informação e melhorias

16.1.1 Responsabilidades e procedimentos: Diretrizes para implementação

Convém que as seguintes diretrizes para o gerenciamento de responsabilidades e procedimentos com relação à gestão de incidentes de segurança da informação sejam considerados:

Convém que responsabilidades pelo gerenciamento sejam estabelecidas para assegurar que os seguintes procedimentos sejam desenvolvidos e comunicados, adequadamente, dentro da organização: 1) procedimentos para preparação e planejamento a resposta a incidente; 2) procedimentos para monitoramento, detecção, análise e notificação de incidentes e eventos de segurança da informação; 3) procedimentos para registros das atividades de gerenciamento de incidentes;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 16 - Gestão de incidentes de segurança da informação

16.1 Gestão de incidentes de segurança da informação e melhorias

16.1.1 Responsabilidades e procedimentos: Informações adicionais

Incidentes de segurança da informação podem transcender os limites organizacionais e nacionais. Para responder a tais incidentes, existe uma crescente necessidade de coordenar resposta e compartilhar informação sobre esses incidentes com organizações externas, quando apropriado.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 16 - Gestão de incidentes de segurança da informação

16.1 Gestão de incidentes de segurança da informação e melhorias

16.1.2 Notificação de eventos de segurança da informação: Controle

Convém que os eventos de segurança da informação sejam relatados por meio dos canais de gestão, o mais rapidamente possível.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 16 - Gestão de incidentes de segurança da informação

16.1 Gestão de incidentes de segurança da informação e melhorias

16.1.2 Notificação de eventos de segurança da informação: Diretrizes para implementação

Convém que todos os funcionários e partes externas sejam alertados sobre sua responsabilidade de notificar qualquer evento de segurança da informação o mais rapidamente possível.

Convém que eles também estejam cientes do procedimento para notificar os eventos de segurança da informação e do ponto de contato, ao qual os eventos devem ser notificados.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 16 - Gestão de incidentes de segurança da informação

16.1 Gestão de incidentes de segurança da informação e melhorias

16.1.2 Notificação de eventos de segurança da informação: Informações adicionais

Mau funcionamento ou outro comportamento anômalo do sistema pode ser um indicador de um ataque de segurança ou violação na segurança atual e, portanto, convém que sempre seja reportado como um evento de segurança da informação.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 16 - Gestão de incidentes de segurança da informação

16.1 Gestão de incidentes de segurança da informação e melhorias

16.1.3 Notificando fragilidades de segurança da informação: Controle

Convém que os funcionários e partes externas que usam os sistemas e serviços de informação da organização sejam instruídos a notificar e registrar quaisquer fragilidades de segurança da informação, observada ou suspeita, nos sistemas ou serviços.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 16 - Gestão de incidentes de segurança da informação

16.1 Gestão de incidentes de segurança da informação e melhorias

16.1.3 Notificando fragilidades de segurança da informação: Diretrizes para implementação

Convém que todos os funcionários e partes externas notifiquem essas questões para o ponto de contato, o mais rápido possível, de forma a prevenir incidentes de segurança da informação. O mecanismo de notificação deve ser fácil, acessível e disponível, sempre que possível.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 16 - Gestão de incidentes de segurança da informação

16.1 Gestão de incidentes de segurança da informação e melhorias

16.1.3 Notificando fragilidades de segurança da informação: Informações adicionais

Convém que funcionários e fornecedores sejam avisados a não tentar provar fragilidades de segurança da informação suspeitas. Testar fraquezas pode ser interpretado como potencial mau uso do sistema e pode também causar danos ao serviço ou sistema de informação e resultar em responsabilidade legal para o indivíduo que executou o teste.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002:

17 - Aspectos da segurança da informação na gestão da continuidade do negócio

17.1 Continuidade da segurança da informação

17.1.1 Planejando a continuidade da segurança da informação

17.1.2 Implementando a continuidade da segurança da informação

17.1.3 Verificação, análise crítica e avaliação da continuidade da segurança da informação

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 17 - Aspectos da segurança da informação na gestão da continuidade do negócio

17.1 Continuidade da segurança da informação

Objetivo: Convém que a continuidade da segurança da informação seja contemplada nos sistemas de gestão da continuidade do negócio da organização

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 17 - Aspectos da segurança da informação na gestão da continuidade do negócio

17.1 Continuidade da segurança da informação

17.1.1 Planejando a continuidade da segurança da informação: Controle

Convém que a organização determine seus requisitos para a segurança da informação e a continuidade da gestão da segurança da informação em situações adversas, por exemplo, durante uma crise ou desastre.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 17 - Aspectos da segurança da informação na gestão da continuidade do negócio

17.1 Continuidade da segurança da informação

17.1.1 Planejando a continuidade da segurança da informação: Diretrizes para implementação

Convém que uma organização avalie se a continuidade da segurança da informação está contida dentro do processo de gestão da continuidade do negócio ou no processo de gestão de recuperação de desastre. Requisitos de segurança da informação podem ser determinados quando do planejamento da continuidade do negócio e da recuperação de desastre.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 17 - Aspectos da segurança da informação na gestão da continuidade do negócio

17.1 Continuidade da segurança da informação

17.1.1 Planejando a continuidade da segurança da informação: Informações adicionais

Para reduzir o tempo e o esforço de uma análise de impacto do negócio adicional, da segurança da informação, é recomendado capturar os aspectos da segurança da informação no gerenciamento da continuidade normal dos negócios ou na análise do impacto ao negócio no gerenciamento da recuperação de um desastre. Isto implica que os requisitos de continuidade da segurança da informação estejam explicitamente contemplados na gestão da continuidade do negócio ou nos processos de gerenciamento da recuperação de desastre

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 17 - Aspectos da segurança da informação na gestão da continuidade do negócio

17.1 Continuidade da segurança da informação

17.1.2 Implementando a continuidade da segurança da informação: Controle

Convém que a organização estabeleça, documente, implemente e mantenha processos, procedimentos e controles para assegurar o nível requerido de continuidade para a segurança da informação, durante uma situação adversa.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 17 - Aspectos da segurança da informação na gestão da continuidade do negócio

17.1 Continuidade da segurança da informação

17.1.2 Implementando a continuidade da segurança da informação: Diretrizes para implementação

Convém que uma organização assegure-se de que: a) uma estrutura de gerenciamento adequada esteja implementada para mitigar e responder a um evento de interrupção, usando pessoal com a necessária autoridade, experiência e competência; b) o pessoal de resposta a incidente com a necessária responsabilidade, autoridade e competência para gerenciar um incidente e garantir a segurança da informação esteja designado;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 17 - Aspectos da segurança da informação na gestão da continuidade do negócio

17.1 Continuidade da segurança da informação

17.1.2 Implementando a continuidade da segurança da informação: Informações adicionais

Dentro do contexto da continuidade do negócio ou da recuperação de desastre, pode ser necessário que procedimentos e processos específicos sejam definidos. Convém que informações que sejam tratadas nestes processos e procedimentos ou em sistemas de informação dedicados para apoiá-los sejam protegidas.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 17 - Aspectos da segurança da informação na gestão da continuidade do negócio

17.1 Continuidade da segurança da informação

17.1.3 Verificação, análise crítica e avaliação da continuidade da segurança da informação: Controle

Convém que a organização verifique os controles de continuidade da segurança da informação, estabelecidos e implementados, a intervalos regulares, para garantir que eles sejam válidos e eficazes em situações adversas.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 17 - Aspectos da segurança da informação na gestão da continuidade do negócio

17.1 Continuidade da segurança da informação

17.1.3 Verificação, análise crítica e avaliação da continuidade da segurança da informação: Diretrizes para implementação

Mudanças organizacionais, técnicas, procedimentos e processos, quando em um contexto operacional ou de continuidade, podem conduzir a mudanças nos requisitos de continuidade da segurança da informação. Em tais casos, convém que a continuidade dos processos, procedimentos e controles para segurança da informação sejam analisados criticamente com base nesses requisitos alterados.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 17 - Aspectos da segurança da informação na gestão da continuidade do negócio

17.1 Continuidade da segurança da informação

17.1.3 Verificação, análise crítica e avaliação da continuidade da segurança da informação: Informações adicionais

A verificação dos controles da continuidade da segurança da informação é diferente das verificações e testes da segurança da informação normal, e convém que seja realizada fora do âmbito dos testes de mudanças. Quando possível é recomendável integrar a verificação dos controles da continuidade da segurança da informação com os testes de recuperação de desastre ou da continuidade dos negócios da organização.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002:

18 - Conformidade

18.1 Conformidade com requisitos legais e contratuais

18.1.1 Identificação da legislação aplicável e de requisitos contratuais

18.1.2 Direitos de propriedade intelectual

18.1.3 Proteção de registros

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 18 Conformidade

18.1 Conformidade com requisitos legais e contratuais

Objetivo: Evitar violação de quaisquer obrigações legais, estatutárias, regulamentares ou contratuais relacionadas à segurança da informação e de quaisquer requisitos de segurança.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 18 Conformidade

18.1 Conformidade com requisitos legais e contratuais

18.1.1 Identificação da legislação aplicável e de requisitos contratuais: Controle

Convém que todos os requisitos legislativos estatutários, regulamentares e contratuais pertinentes e o enfoque da organização para atender a esses requisitos sejam explicitamente identificados, documentados e mantidos atualizados para cada sistema de informação da organização.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 18 Conformidade

18.1 Conformidade com requisitos legais e contratuais

18.1.1 Identificação da legislação aplicável e de requisitos contratuais: Diretrizes para implementação

Convém que os controles específicos e as responsabilidades individuais para atender a estes requisitos sejam definidos e documentados.

Convém que os gestores identifiquem toda a legislação aplicável à sua organização, para atender aos requisitos relativos ao seu tipo de negócio.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 18 Conformidade

18.1 Conformidade com requisitos legais e contratuais

18.1.1 Identificação da legislação aplicável e de requisitos contratuais: Informações adicionais

Caso a organização realize negócios em outros países, convém que os gestores considerem a conformidade em todos esses países.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 18 Conformidade

18.1 Conformidade com requisitos legais e contratuais

18.1.2 Direitos de propriedade intelectual: Controle

Convém que procedimentos apropriados sejam implementados para garantir a conformidade com os requisitos legislativos, regulamentares e contratuais relacionados aos direitos de propriedade intelectual, e sobre o uso de produtos de software proprietários.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 18 Conformidade

18.1 Conformidade com requisitos legais e contratuais

18.1.2 Direitos de propriedade intelectual: Diretrizes para implementação

Convém que as seguintes diretrizes sejam consideradas para proteger qualquer material que possa ser considerado propriedade intelectual: a) divulgar uma política de conformidade com os direitos de propriedade intelectual que defina o uso legal de produtos de software e de informação; b) adquirir software somente por meio de fontes conhecidas e de reputação, para assegurar que o direito autoral não esteja sendo violado;

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 18 Conformidade

18.1 Conformidade com requisitos legais e contratuais

18.1.2 Direitos de propriedade intelectual: Informações adicionais

Direitos de propriedade intelectual incluem direitos autorais de software ou documento, direitos de projetos, marcas, patentes e licenças de código-fonte.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 18 Conformidade

18.1 Conformidade com requisitos legais e contratuais

18.1.3 Proteção de registros: Controle

Convém que registros sejam protegidos contra perda, destruição, falsificação, acesso não autorizado e liberação não autorizada, de acordo com os requisitos regulamentares, estatutários, contratuais e do negócio.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 18 Conformidade

18.1 Conformidade com requisitos legais e contratuais

18.1.3 Proteção de registros: Diretrizes para implementação

Convém que, quando a organização decidir proteger os registros específicos, a classificação correspondente seja baseada no esquema de classificação da organização.

Convém que os registros sejam categorizados em tipos de registros, como registros contábeis, registros de base de dados, registros de transações, registros de auditoria e procedimentos operacionais, cada qual com detalhes do período de retenção e do tipo de mídia de armazenamento, como, por exemplo, papel, microficha, meio magnético ou ótico.

Convém que quaisquer chaves de criptografia relacionadas com arquivos cifrados ou assinaturas digitais (ver Seção 10) sejam armazenadas para permitir a decifração de registros pelo período de tempo que os registros são mantidos.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

#ABNT NBR ISO/IEC 27002: 18 - Conformidade

18.1 Conformidade com requisitos legais e contratuais

18.1.3 Proteção de registros: Informações adicionais

Alguns registros podem precisar ser retidos de forma segura para atender a requisitos estatutários, regulamentares ou contratuais, bem como para apoiar as atividades essenciais do negócio.

ENGENHARIA DE SEGURANÇA PARA SOFTWARE

- **F I M**